FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

# Fraud scenarios, target controls and implementation programme

On its own answers, the organisation reports the controls in place for 46 of the 106 fraud scenarios that apply and a control reported as a gap in 58.

CALCULATED TEST RESULT
**55.1 of 100, test fixture**

UNRESOLVED INCONSISTENCIES
**None found**

PROVISIONAL MANAGEMENT INTERPRETATION
**58 with a control reported as a gap**

APPROVED READINESS CONCLUSION
**None issued**

PREPARED FOR

## Fictional Retail Group (extensive unanswered information)

Assessment reference · FX-P5

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

HOW TO READ THIS REPORT

# Contents


| Management report | SECTIONS 1–9 |
|---|---|
| 1 · Where the organisation stands | |
| 2 · What is driving the position | |
| 3 · Reported fraud scenarios | |
| 4 · How the scenarios could occur | |
| 5 · The control environment management should build | |
| 6 · Who must own the response | |
| 7 · Decisions leadership must make | |
| 8 · Proposed implementation stages | |
| 9 · How management will know it is working | |

| Registers | APPENDICES A–J |
|---|---|
| A · Finding register | 59 entries |
| B · Fraud risk register | 58 entries |
| C · Control blueprint register | 103 entries |
| D · Records management should maintain | 102 entries |
| E · Action register | 43 entries |
| F · Management scorecard | 103 entries |
| G · Answer relationships | 4 entries |
| H · Outstanding information | 7 entries |
| I · Roles used in this report | 11 entries |
| J · Information coverage | 10 entries |


**THE TWO HALVES OF THIS REPORT**

Sections 1–9 are the management report. The appendices hold every scenario, risk, control blueprint, record, action, measure, answer relationship and outstanding answer behind it, and the supporting workbook holds the same registers with the method references that trace each row to the question asked and the answer given.

**BASIS OF THIS REPORT**

TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating. This report is produced by fixed rules from the organisation's answers to the MK Fraud Readiness review, read against the draft review method and the draft control-content library, neither of which MK has yet approved. The AI manuscript stage has not been run; the interpretation in each section is fixed-rule text. No evidence has been examined, no control has been tested for operating effectiveness, no one has been interviewed and no assurance opinion is given. Records named in this report are records management should maintain; independent review of evidence is a separate Advisory service.

SECTION 1 · WHERE THE ORGANISATION STANDS

# What the assessment establishes

Four separate statements, made the same way for every organisation: what was calculated, what is inconsistent, how the answers read, and what has been concluded. Nothing here has been tested or verified.

CALCULATED TEST RESULT

### 55.1 of 100, test fixture

From a research simulation of the draft method, kept for traceability. It is not a score, a maturity band or a readiness level.

PROVISIONAL MANAGEMENT INTERPRETATION

### 58 with a control reported as a gap

On its own answers, the organisation reports the controls that stop the scenario in place for 46 of the 106 fraud scenarios that apply, and a control reported as a gap in 58; 2 cannot be read because answers are outstanding. This reads self-reported answers; nothing has been tested.

UNRESOLVED INCONSISTENCIES

### None found

None found in the 1 pair of answers compared. Most related practices were not asked, so this is not a finding that every answer is consistent.

APPROVED READINESS CONCLUSION

### None issued

MK has not approved a readiness method, band or threshold, so no readiness conclusion is drawn from the answers or from the calculated test result.

| AREA | SCENARIOS | IN PLACE | IN PLACE, RELATED PRACTICE WEAKER | GAP | TO SETTLE | TO CLARIFY | NOT ANALYSED | CALCULATED TEST RESULT* |
|---|---|---|---|---|---|---|---|---|
| **Fraud governance and accountability** | 12 | 12 | 0 | 0 | 0 | 0 | 0 | 90.0 |
| **Fraud risk assessment** | 6 | 5 | 0 | 0 | 0 | 0 | 1 | 90.0 |
| **Ethics, integrity and anti-corruption** | 10 | 8 | 1 | 1 | 0 | 0 | 0 | 81.0 |
| **Third parties and supply chain** | 13 | 0 | 0 | 13 | 0 | 0 | 0 | 19.3 |
| **People, payroll and insider risk** | 11 | 0 | 0 | 11 | 0 | 0 | 0 | 26.4 |
| **Finance, banking and financial reporting** | 12 | 12 | 0 | 0 | 0 | 0 | 0 | 92.5 |
| **Customers, revenue and products** | 10 | 0 | 0 | 10 | 0 | 0 | 0 | 25.0 |
| **Assets, cash and inventory** | 10 | 0 | 0 | 9 | 0 | 0 | 1 | 21.1 |
| **Digital, cyber-enabled and identity fraud** | 14 | 0 | 0 | 14 | 0 | 0 | 0 | 18.6 |
| **Detection, speak-up and response** | 8 | 8 | 0 | 0 | 0 | 0 | 0 | 86.7 |

* TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating. Shown for traceability only: not a score, a band or a ranking of the areas.

WHAT THIS MEANS

The organisation answered 106 of the 108 confirmations that apply, 45 of 45 in the core stage, and 7 questions are outstanding (Appendix H). Of the diagnostic questions put to it, 62 of 67 were answered; the rest of the method's diagnostic questions were not asked, and nothing is concluded about them (Appendix J). The tier of a scenario says how early the method asks about it, not how serious it is, and the calculated test result is not a readiness level.

SECTION 2 · WHAT IS DRIVING THE POSITION

# The patterns behind the answers

Answers to settle and questions to clarify first, because a control relied on as reported may not operate that way; then requirements that span areas, and the count of gaps by area.

## Requirements that span several areas

The method groups some controls into requirements that cross areas. Where two or more of them are reported as gaps in different areas, the weakness is connected: fixing one area leaves the route open through another.

| REQUIREMENT | CONTROLS REPORTED AS GAPS | IN PLACE OF THOSE ASKED |
|---|---|---|
| **Changes to payment details are verified through a route the requester does not control** | Change confirmed with supplier (procurement: partly in place); Familiar caller still verified (procurement: not in place); Bank changes confirmed with employee (people: not in place); Customer detail changes verified (customers: partly in place); Changes to call-back details verified (digital channels: partly in place); Email never enough on its own (digital channels: not in place) | 1 of 7 |
| **Identity is established through routes an impersonator cannot control** | Identity verified (people: partly in place); Remote appointee identity confirmed (people: partly in place); Help desk resets verified (digital channels: partly in place); Verification for calls, voice notes and video (digital channels: partly in place); Familiar caller still verified (procurement: not in place) | 0 of 5 |
| **Independent assurance examines high-risk processes** | Independent review of procurement (procurement: partly in place); Independent review of payroll (people: partly in place) | 0 of 2 |

## Scenarios with a control reported as a gap, by area

| AREA | SCENARIOS WITH A GAP | SCENARIOS IN THE AREA |
|---|---|---|
| **Ethics, integrity and anti-corruption** | 1 | 10 |
| **Third parties and supply chain** | 13 | 13 |
| **People, payroll and insider risk** | 11 | 11 |
| **Customers, revenue and products** | 10 | 10 |
| **Assets, cash and inventory** | 9 | 10 |
| **Digital, cyber-enabled and identity fraud** | 14 | 14 |

Areas in the method's order. A count of scenarios is not a measure of their seriousness.

WHAT THIS MEANS

No answers conflict in the pairs compared, and no reviewed pair leaves a question open. 3 requirements span several areas with gaps in more than one. 58 scenarios have a control reported as a gap, across 6 areas.

SECTION 3 · REPORTED FRAUD SCENARIOS

# The scenarios this report acts on, by area

Every scenario with answers to settle, a question to clarify or a control reported as a gap, in the method's order. MK has not approved a method for rating fraud risks, so no likelihood, impact, materiality or priority is assigned, and neither the order nor the tier is a ranking. Each scenario's finding is in Appendix A and its risk statement in Appendix B.

| AREA | ACTED ON | SCENARIOS |
|---|---|---|
| **Ethics, integrity and anti-corruption** | 1 | Donations or sponsorships channel bribes S26 |
| **Third parties and supply chain** | 13 | A fictitious supplier is created and paid S29; Supplier payments are diverted through changed bank details S30; A supplier is set up with an account it does not own S31; One person can order and approve payment S32; Invoices are paid for goods or services not received or not agreed S33; An outsourced provider misuses its access S34; Supplier payments are released without two approvals S35; A tender is manipulated or purchases are split S36; Buyers take kickbacks S37; Purchase cards or petty cash are misused S38; Intermediaries pay bribes or inflate fees S39; Procurement anomalies are never noticed S40; Variations inflate the agreed value S41 |
| **People, payroll and insider risk** | 11 | Salaries are redirected through a fake bank change S42; Ghost employees are paid S43; Leavers stay on the payroll S44; A false identity enters at hiring S45; A stand-in or deepfake candidate is appointed S46; The payroll payment file is altered after approval S47; Cash wages are stolen or paid to ghosts S48; Hours and overtime are inflated S49; Expenses and advances are abused S50; Labour brokers invoice for workers who were not there S51; An insider in a high-risk role works unchecked S52 |
| **Customers, revenue and products** | 10 | Refunds are stolen S65; Customer details are changed to divert money or goods S66; Credit is obtained with fabricated documents S67; Claims are fabricated or inflated S68; Sales are not billed or receipts are diverted S69; Customers pay fraudsters impersonating the organisation S70; Prices are overridden or side deals made S71; Agents report fictitious sales S72; Vouchers and loyalty points are abused S73; Customers are wrongly blocked on a fraud flag S74 |
| **Assets, cash and inventory** | 9 | Cash takings are stolen S75; Stock is stolen and hidden in the counts S76; Data leaves on disposed or reissued devices S78; Assets or scrap are sold off cheaply or without payment S79; Goods are released to an impostor S80; Fuel and fleet are misused S81; Goods go missing in transit S82; High-value materials are stolen by organised groups S83; Losses are never tracked S84 |
| **Digital, cyber-enabled and identity fraud** | 14 | An email account is taken over S85; A payment instruction received by email is acted on S86; A cloned voice or video instruction is obeyed S87; Customer accounts are taken over S88; A security compromise is not notified S89; A help desk reset hands an attacker access S90; Systems that move money are accessed without strong sign-in S91; Personal information is over-exposed or kept too long S92; A SIM swap defeats one-time PIN approvals S93; An AI assistant is manipulated by hidden instructions S94; The organisation's own information helps attackers S95; A compromise is not contained quickly S96; The organisation is impersonated to defraud others S97; Spoofed email in the organisation's name deceives staff, suppliers or customers S98 |

A further 1 scenario has the control that stops it reported in place with a related practice weaker. They are in Appendix A, and the related practices in Appendix C.

WHAT THIS MEANS

58 scenarios are acted on across 6 areas. The grouping shows where the work sits; Section 7 asks management to decide the order, using explicit factors.

SECTION 4 · HOW THE SCENARIOS COULD OCCUR

# Illustrative exposure mechanisms

Included: every scenario with answers to settle or a question to clarify (up to three), then the first scenario with a control reported as a gap in each area, in the method's order, up to six in all. They are plausible pathways for an organisation with the controls it reported, not allegations that any event has occurred, and their inclusion is not a ranking.

## Donations or sponsorships channel bribes

S26 · ETHICS

| | |
|---|---|
| HOW IT STARTS | A payment to a cause linked to a decision-maker buys influence. |
| WHY IT MATTERS | The method links it to donations and sponsorships used as disguised bribes and undeclared conflicts of interest steering decisions. |
| WHAT THE ANSWERS SHOW | Recipients checked for links: reported in place only in some areas, cases or periods. |
| WHAT WOULD INTERRUPT IT | Before any donation or sponsorship is committed, the recipient is checked for links to public officials, customers' decision-makers and employees, and any link found is disclosed and approved. |
| WARNING SIGNS | Donations and sponsorships used as disguised bribes; Undeclared conflicts of interest steering decisions |
| LINKS | F02, FR01, C02 |

## A fictitious supplier is created and paid

S29 · PROCUREMENT

| | |
|---|---|
| HOW IT STARTS | An insider or outsider adds a supplier that does not exist and invoices it. |
| WHY IT MATTERS | Fictitious suppliers enter through onboarding that can be skipped. |
| WHAT THE ANSWERS SHOW | New supplier process: checks happen only when someone thinks to do them. Behind it, directors identified is partly in place, directors compared with staff is not in place and suppliers re-checked is set out, not yet operating. |
| WHAT WOULD INTERRUPT IT | Every new supplier passes set checks, including registration, tax number, bank account and directors, and is approved before it can be paid. |
| WARNING SIGNS | Fictitious or shell suppliers |
| LINKS | F03, FR02, C03, C04, C05, C06, C07 |

## Salaries are redirected through a fake bank change

S42 · PEOPLE

| | |
|---|---|
| HOW IT STARTS | A request that appears to come from an employee changes where their salary is paid. |
| WHY IT MATTERS | Salary redirection through fake bank change requests is common and fast. |
| WHAT THE ANSWERS SHOW | Bank changes confirmed with employee: bank detail changes are made as requested. |
| WHAT WOULD INTERRUPT IT | Every change to an employee's bank details is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect. |
| WARNING SIGNS | Salary redirection through changed bank details |
| LINKS | F16, FR15, C32 |

## Refunds are stolen

S65 · CUSTOMERS

| | |
|---|---|
| HOW IT STARTS | One person raises and approves refunds or credit notes to themselves or accomplices. |
| WHY IT MATTERS | Refunds processed and approved by one person are a classic way to steal. |
| WHAT THE ANSWERS SHOW | Refunds approved independently: approval is sought only for large refunds or when staff are unsure. Behind it, returns received before credit is not in place, refund patterns reviewed is partly in place and post-period reversals reviewed is partly in place. |
| WHAT WOULD INTERRUPT IT | Every refund and credit note is approved by someone other than the person who processes it. |
| WARNING SIGNS | False refunds, credit notes and returns |
| LINKS | F27, FR26, C51, C52, C53, C54, C55 |

### Cash takings are stolen

S75 · ASSETS

| | |
|---|---|
| HOW IT STARTS | Takings are under-recorded or removed before banking. |
| WHY IT MATTERS | Daily reconciliation of takings is the main control over cash theft. |
| WHAT THE ANSWERS SHOW | Daily reconciliation: takings are reconciled occasionally, or only when there is a shortage. |
| WHAT WOULD INTERRUPT IT | Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated. |
| WARNING SIGNS | Theft of cash; Sales skimmed before they are recorded |
| LINKS | F37, FR36, C73 |

### An email account is taken over

S85 · DIGITAL CHANNELS

| | |
|---|---|
| HOW IT STARTS | A mailbox without strong sign-in is used to send or intercept payment instructions. |
| WHY IT MATTERS | Most business email compromise starts with an account that has no multi-factor authentication. |
| WHAT THE ANSWERS SHOW | Multi-factor on all email: email accounts are protected by passwords only. |
| WHAT WOULD INTERRUPT IT | Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions. |
| WARNING SIGNS | Takeover of staff accounts; Business email compromise and payment redirection |
| LINKS | F46, FR45, C87 |

52 further scenarios are described in Appendices A and B.

SECTION 5 · THE CONTROL ENVIRONMENT MANAGEMENT SHOULD BUILD

# Target controls, by accountable role

One programme for each accountable role, in alphabetical order. Each control's blueprint, with its target practice, activities, records and success measure, is in Appendix C; here it is named with its reference.

## Chief financial officer

5 CONTROLS

| | |
|---|---|
| SCENARIOS | a payment instruction received by email is acted on, a cloned voice or video instruction is obeyed and the organisation is impersonated to defraud others. |
| PUT IN PLACE | Email never enough on its own (C88); Verification for calls, voice notes and video (C89); Brand impersonation monitored and removed (C102). |
| STRENGTHEN | Executives and their teams prepared (C90); Changes to call-back details verified (C91). |

## Commercial and customer lead

14 CONTROLS

| | |
|---|---|
| SCENARIOS | refunds are stolen, customer details are changed to divert money or goods, claims are fabricated or inflated, prices are overridden or side deals made, agents report fictitious sales and vouchers and loyalty points are abused and 1 more. |
| PUT IN PLACE | Refunds approved independently (C51); Customer detail changes verified (C58); Fraud indicators screened (C66); Non-standard prices approved (C69); Agent sales verified (C70); Vouchers controlled in the system (C71); Staff guided on what not to share (C100). |
| STRENGTHEN | Returns received before credit (C52); Refund patterns reviewed (C53); Post-period reversals reviewed (C54); Claim evidence checked for AI (C55); Defined onboarding (C56); Business customers verified (C57); Shared details flagged (C59). |

## Ethics lead

1 CONTROL

| | |
|---|---|
| SCENARIOS | donations or sponsorships channel bribes. |
| PUT IN PLACE | Recipients checked for links (C02). |

## Finance lead

23 CONTROLS

| | |
|---|---|
| SCENARIOS | supplier payments are diverted through changed bank details, invoices are paid for goods or services not received or not agreed, supplier payments are released without two approvals, purchase cards or petty cash are misused, procurement anomalies are never noticed and cash wages are stolen or paid to ghosts and 7 more. |
| PUT IN PLACE | Change confirmed with supplier (C08); Familiar caller still verified (C09); Three-way match (C16); Two approvers on banking platform (C18); Independent reconciliation (C22); Senior review of supplier payments (C27); Two people pay out cash (C41); Claims approved by a manager (C43); Application documents verified (C61); Everything supplied is billed (C67); Customers warned about payment redirection (C68); Independent blind counts (C75); Paid before collection (C81); Losses tracked and reported (C86). |
| STRENGTHEN | Credit approved independently (C60); Bureau and fraud database checks (C62); Early defaults investigated (C63); Limit and terms changes approved (C64); Statements sent from the system (C65); Full counts (C74); Differences explained before adjusting (C76); Write-offs approved and supervised (C77); Shrinkage tracked (C78). |

## Fraud risk lead

1 CONTROL

| | |
|---|---|
| SCENARIOS | customers are wrongly blocked on a fraud flag. |
| PUT IN PLACE | Human review before a customer is blocked (C72). |

### HR and payroll lead

17 CONTROLS

| | |
|---|---|
| SCENARIOS | salaries are redirected through a fake bank change, ghost employees are paid, leavers stay on the payroll, a false identity enters at hiring, a stand-in or deepfake candidate is appointed and the payroll payment file is altered after approval and 2 more. |
| PUT IN PLACE | Bank changes confirmed with employee (C32); Payroll reviewed by another person (C33); Leavers removed before next run (C36); Identity verified (C37); Remote appointee identity confirmed (C39); Payment file protected (C40); Hours approved by supervisor (C42); Block leave required (C48). |
| STRENGTHEN | Training on joining (C01); Headcount verification done (C34); Independent review of payroll (C35); Qualifications verified (C38); High-risk roles identified (C45); No conflicting duties when covering (C46); No single point of knowledge (C47); Concerns raised fairly (C49); Support for financial pressure (C50). |

### Internal audit

2 CONTROLS

| | |
|---|---|
| STRENGTHEN | Data reviewed for unusual patterns (C24); Independent review of procurement (C25). |

### IT lead

10 CONTROLS

| | |
|---|---|
| SCENARIOS | data leaves on disposed or reissued devices, an email account is taken over, customer accounts are taken over, a security compromise is not notified, a help desk reset hands an attacker access and systems that move money are accessed without strong sign-in and 4 more. |
| PUT IN PLACE | Devices wiped before disposal (C80); Multi-factor on all email (C87); Customer logins protected (C92); Compromises reported as POPIA requires (C93); Help desk resets verified (C95); Multi-factor on critical systems (C96); Approval numbers protected (C98); Assistant permissions limited (C99); Compromise playbook (C101); Domain protected against spoofing (C103). |

### Legal and compliance lead

3 CONTROLS

| | |
|---|---|
| SCENARIOS | buyers take kickbacks and personal information is over-exposed or kept too long. |
| PUT IN PLACE | Annual interest declarations (C21); Access to personal information limited (C97). |
| STRENGTHEN | Affected people warned (C94). |

### Operations lead

10 CONTROLS

| | |
|---|---|
| SCENARIOS | labour brokers invoice for workers who were not there, cash takings are stolen, goods are released to an impostor, fuel and fleet are misused, goods go missing in transit and high-value materials are stolen by organised groups. |
| PUT IN PLACE | Broker invoices against attendance (C44); Daily reconciliation (C73); Changed collection instructions verified (C82); Fuel matched to distance (C83); Dispatch matched to orders (C84); Organised theft assessed (C85). |
| STRENGTHEN | Receipt recorded before payment (C13); Quantities checked (C14); Services confirmed (C15); How stock is recorded (C79). |

### Procurement lead

17 CONTROLS

| | |
|---|---|
| SCENARIOS | a fictitious supplier is created and paid, a supplier is set up with an account it does not own, one person can order and approve payment, an outsourced provider misuses its access, a tender is manipulated or purchases are split and intermediaries pay bribes or inflate fees and 1 more. |
| PUT IN PLACE | New supplier process (C03); Bank account verified (C10); Orderer is not payment approver (C11); Provider access limited (C17); Evaluation against set criteria (C20); Intermediaries vetted (C23); Variations approved first (C29). |
| STRENGTHEN | Directors identified (C04); Directors compared with staff (C05); Suppliers re-checked (C06); Dormant suppliers deactivated (C07); Approved order before commitment (C12); Quote and tender thresholds (C19); Split orders monitored (C26); Contract register (C28); Large variations escalated (C30); Written supplier contracts (C31). |

**WHAT THIS MEANS**

59 controls are to be put in place and 44 are related practices to strengthen. No reviewed relationship establishes that one of these controls consumes another's output, so no control is sequenced before another for that reason. Each blueprint comes from MK's draft control-content library (control-content-library-0.1), which MK has not yet approved.

SECTION 6 · WHO MUST OWN THE RESPONSE

# Accountability by role

Roles, not individuals: the assessment does not identify people. The method suggests owners in many forms; this report uses one label per function, and Appendix I lists the method's wording behind each. Oversight: the board, from the organisation's own answer.

| ROLE | CONTROLS | SCENARIOS | ACTIONS | ANSWERS TO SETTLE OR QUESTIONS TO ANSWER |
|---|---|---|---|---|
| **Chief executive** | 0 | 58 | 9 | Names the accountable executives, decides the order of work and reports status to the board. |
| **Chief financial officer** | 5 | 3 | 3 | None |
| **Commercial and customer lead** | 14 | 7 | 4 | None |
| **Ethics lead** | 1 | 1 | 3 | None |
| **Finance lead** | 23 | 13 | 4 | None |
| **Fraud risk lead** | 1 | 1 | 3 | None |
| **HR and payroll lead** | 17 | 9 | 4 | None |
| **Internal audit** | 2 | 1 | 2 | None |
| **IT lead** | 10 | 10 | 2 | None |
| **Legal and compliance lead** | 3 | 3 | 3 | None |
| **Operations lead** | 10 | 8 | 3 | None |
| **Procurement lead** | 17 | 9 | 3 | None |

SECTION 7 · DECISIONS LEADERSHIP MUST MAKE

# The decision agenda

A recommended direction follows the method and the answers; the decision remains management's. No deadline is set: "when" states what each decision must come before.

| REF | DECISION | WHY | RECOMMENDED DIRECTION | WHEN | IF DELAYED |
|---|---|---|---|---|---|
| D01 | **Require an answer, or a recorded open item, for each of the 7 outstanding questions.** | Of these, 7 were not known. Nothing is concluded about them. | Assign each to a named person, and record any that cannot be answered as an open item. | Before the scenarios they affect are ordered. | The scenarios they affect stay unknown rather than covered. |
| D02 | **Name one accountable executive for each area with open or unresolved scenarios: ethics (1), procurement (13), people (11), customers (10), assets (9) and digital channels (14).** | Each scenario needs one person with authority over the process, the system and the people involved. | The method suggests: ethics lead for ethics, procurement lead for procurement, HR and payroll lead for people, commercial and customer lead for customers and operations lead for assets, and the leads named in the register for the rest. | Before design work starts. | Open scenarios have no owner, and the controls that stop them stay unassigned. |
| D03 | **Decide the order in which the open scenarios are addressed, using explicit factors.** | MK has not approved a method for rating fraud risks, so this report does not rank them, and neither its order nor the method's tiers is a ranking. | Settle conflicting answers and open questions first. Then weigh, for each scenario, how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much activity passes through the process, whether another control would detect a loss, and how many other scenarios the same control serves. The finding register gives the facts the assessment holds for the first and last of these; management supplies the rest. | Before design work starts. | Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking. |
| D04 | **Have the board receive the status of the open and unresolved scenarios at each of its meetings until each is closed, deferred with a reason or accepted.** | Regular reporting keeps the scenarios visible to the people who can remove blockers. | A one-page status per scenario: owner, controls in place, controls outstanding, next step. | From the first meeting after this report. | Progress is not visible until the next assessment. |

SECTION 8 · PROPOSED IMPLEMENTATION STAGES

# A twelve-month programme, in proposed stages

Each stage has a proposed planning window for when it could start. The windows are proposals for management's own plan: not deadlines, not contractual dates and not estimates of how long any control takes to design, put in place or show to be operating. Every action is in Appendix E.

| STAGE | STAGE | PROPOSED WINDOW | PURPOSE | ACTIONS | INCLUDES |
|---|---|---|---|---|---|
| 1 | **Establish the facts** | Proposed start: month 1 | Settle answers that cannot both be right, answer the questions the answers leave open, and obtain outstanding answers, so that nothing is built on an answer that may be wrong. | 5 | Obtain the 2 outstanding answers held by Risk and investigations: process owners take part and updated when the business changes. Obtain the 1 outstanding answer held by HR and payroll: payroll data analysed. 3 more in Appendix E. |
| 2 | **Decide and assign** | Proposed start: months 1 to 3 | Name who is accountable for each area, decide the order of work using explicit factors, and approve the target designs. | 8 | Name the executive accountable for ethics, where 1 scenario is open or unresolved. Name the executive accountable for procurement, where 13 scenarios are open or unresolved. 6 more in Appendix E. |
| 3 | **Put the selected controls in place** | Proposed start: once designs are approved | The controls reported as gaps for the scenarios management has selected. | 10 | Put in place the control the ethics lead owns: recipients checked for links (C02). Put in place the 7 controls the procurement lead owns: new supplier process (C03), bank account verified (C10), orderer is not payment approver (C11), provider access limited (C17), evaluation against set criteria (C20) and intermediaries vetted (C23) and 1 more. 8 more in Appendix E. |
| 4 | **Strengthen further defences** | Proposed start: after the first controls are in place | Related practices reported weaker behind a control reported in place or a gap. | 8 | Strengthen the 9 controls the HR and payroll lead owns: training on joining (C01), headcount verification done (C34), independent review of payroll (C35), qualifications verified (C38), high-risk roles identified (C45) and no conflicting duties when covering (C46) and 3 more. Strengthen the 10 controls the procurement lead owns: directors identified (C04), directors compared with staff (C05), suppliers re-checked (C06), dormant suppliers deactivated (C07), approved order before commitment (C12) and quote and tender thresholds (C19) and 4 more. 6 more in Appendix E. |
| 5 | **Operate, measure and report** | From the first control in operation, through month 12 | Run each control through at least one full operating cycle, check it against its success measure and report status to the oversight body. | 12 | Check each of the 17 controls owned by the HR and payroll lead against its success measure once it has completed its first full operating cycle. Check the control owned by the ethics lead against its success measure once it has completed its first full operating cycle. 10 more in Appendix E. |

WHAT THIS MEANS

The first two stages need no new control: they establish the facts, name owners and decide the order of work. No control here consumes another's output as far as reviewed relationships establish, so no prerequisite stage is needed. A control counts as working only after it has met its success measure for at least one full operating cycle; for annual controls that may fall beyond the twelve months. Status is reported to the board throughout.

SECTION 9 · HOW MANAGEMENT WILL KNOW IT IS WORKING

# Indicators and the management scorecard

Each control has one success measure, stated as the outcome its records should show for a period (Appendix F). They are the signals management should expect once a control operates, not a claim that they exist today.

| INDICATOR | TODAY | EXPECTED |
|---|---|---|
| **Outstanding answers** | 7 | Each answered, or an open item with an owner |
| **Open scenarios with a named owner and a recorded decision** | None recorded (58 open) | Every open scenario selected, deferred with a reason or accepted |
| **Controls meeting their success measure for a full cycle** | Not measured | Each control put in place (59), then each related practice strengthened |
| **Status reported to the board** | Not yet | At each meeting until each scenario is closed, deferred or accepted |

## The scorecard, by owner

| OWNER | MEASURES | MOST COMMON OPERATING CYCLES |
|---|---|---|
| **Chief financial officer** | 5 | each year (3); whenever a change is requested (1); weekly (1) |
| **Commercial and customer lead** | 14 | monthly (3); before each account is opened (2); before each refund is paid (1) |
| **Ethics lead** | 1 | before each commitment (1) |
| **Finance lead** | 23 | monthly (6); each year (2); before each payment (2) |
| **Fraud risk lead** | 1 | each year (1) |
| **HR and payroll lead** | 17 | each year (5); each pay run (4); monthly (1) |
| **Internal audit** | 2 | monthly (1); within the last two years (1) |
| **IT lead** | 10 | monthly (3); each quarter (3); each year (2) |
| **Legal and compliance lead** | 3 | each year and when circumstances change (1); each year (1); each quarter (1) |
| **Operations lead** | 10 | before each payment (3); at each delivery (1); daily (1) |
| **Procurement lead** | 17 | before each new supplier is first paid (3); each year (3); each quarter (3) |

CONCLUSION

On its own answers, Fictional Retail Group (extensive unanswered information) reports the controls in place for 46 of 106 fraud scenarios and a control reported as a gap in 58. MK has not approved a readiness method, so the report draws no readiness conclusion and does not rank fraud risks; it sets out what each scenario needs, who owns it, the records to keep and how management will know each control is working.

APPENDIX A

# Finding register

Every scenario with answers to settle, a question to clarify, a control reported as a gap or a related practice weaker, in the method's order. "What the answers show" is self-reported and has not been verified. Decision factors are the facts the assessment holds for ordering the work; they are not a rating.

| REF | SCENARIO | WHAT THE ANSWERS SHOW | HOW IT HAPPENS AND WHY IT MATTERS (METHOD) | DECISION FACTORS |
|---|---|---|---|---|
| F01<br>S25 | **Staff do not know or understand what is expected**<br>Ethics, integrity and anti-corruption<br>CONTROL IN PLACE; RELATED PRACTICE WEAKER | Code accessible to staff: reported in place across everything it should cover. Related practices reported weaker: training on joining (partly in place).<br>Answered by the respondent, HR and payroll and Legal, compliance and ethics. | Expectations are not communicated in a way people understand, and nobody checks. | In place; related practice weaker C01 |
| F02<br>S26 | **Donations or sponsorships channel bribes**<br>Ethics, integrity and anti-corruption<br>CONTROL REPORTED AS A GAP | Recipients checked for links: reported in place only in some areas, cases or periods.<br>Answered by the respondent. | A payment to a cause linked to a decision-maker buys influence. | Partly in place FR01, C02 |
| F03<br>S29 | **A fictitious supplier is created and paid**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | New supplier process: checks happen only when someone thinks to do them. Related practices also reported weaker: directors identified (partly in place), directors compared with staff (not in place), suppliers re-checked (set out, not yet operating) and dormant suppliers deactivated (not in place).<br>Answered by the respondent and Procurement. | An insider or outsider adds a supplier that does not exist and invoices it. Fictitious suppliers enter through onboarding that can be skipped. | Partly in place FR02, C03, C04, C05, C06, C07 |
| F04<br>S30 | **Supplier payments are diverted through changed bank details**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Change confirmed with supplier: changes are confirmed, but sometimes using contact details taken from the request itself. Familiar caller still verified: a follow-up call from the 'supplier' is accepted as confirmation.<br>Answered by the respondent. | A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed. Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition. | Not in place FR03, C08, C09 |
| F05<br>S31 | **A supplier is set up with an account it does not own**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Bank account verified: accounts are verified through a bank or third-party service for most new suppliers.<br>Answered by the respondent. | Payments go to an employee's or fraudster's account from the first invoice. Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe. | Partly in place FR04, C10 |
| F06<br>S32 | **One person can order and approve payment**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Orderer is not payment approver: the same person can order and approve payment.<br>Answered by Procurement. | A buyer invents or inflates a purchase and approves its payment. One person who can both order and approve payment can pay a supplier they invented. | Not in place FR05, C11 |
| F07<br>S33 | **Invoices are paid for goods or services not received or not agreed**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Three-way match: invoices are paid without being checked against what was approved or received. Related practices also reported weaker: approved order before commitment (partly in place), receipt recorded before payment (partly in place), quantities checked (not in place) and services confirmed (not in place).<br>Answered by Procurement, Operations and sales and Finance. | Overbilling, fictitious deliveries or inflated rates are paid. Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid. | Not in place FR06, C16, C12, C13, C14, C15 |
| F08<br>S34 | **An outsourced provider misuses its access**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Provider access limited: access is limited to what the service needs for the main providers.<br>Answered by the respondent. | A provider that handles money, customers or data has wider access than the service needs. Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought. | Partly in place FR07, C17 |

| REF | SCENARIO | WHAT THE ANSWERS SHOW | HOW IT HAPPENS AND WHY IT MATTERS (METHOD) | DECISION FACTORS |
|---|---|---|---|---|
| F09<br>S35 | **Supplier payments are released without two approvals**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Two approvers on banking platform: a second approval happens sometimes.<br>Answered by Procurement. | One person releases a payment run. | Partly in place<br>FR08, C18 |
| F10<br>S36 | **A tender is manipulated or purchases are split**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Evaluation against set criteria: criteria exist, but they are sometimes set or changed after bids arrive. Related practices also reported weaker: quote and tender thresholds (not in place).<br>Answered by Procurement. | Specifications, evaluation or thresholds are bent towards a chosen supplier. | Partly in place<br>FR09, C20, C19 |
| F11<br>S37 | **Buyers take kickbacks**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Annual interest declarations: buying staff do not declare interests.<br>Answered by Procurement. | A long-standing buyer-supplier relationship hides favours. | Not in place<br>FR10, C21 |
| F12<br>S38 | **Purchase cards or petty cash are misused**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Independent reconciliation: reported as not in place.<br>Answered by Procurement. | Personal purchases or split transactions go unreviewed. | Not in place<br>FR11, C22 |
| F13<br>S39 | **Intermediaries pay bribes or inflate fees**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Intermediaries vetted: reported as not in place.<br>Answered by Procurement. | Agents act improperly or bill for work not done. | Not in place<br>FR12, C23 |
| F14<br>S40 | **Procurement anomalies are never noticed**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Senior review of supplier payments: reported as set out or agreed but not yet working in practice. Related practices also reported weaker: split orders monitored (set out, not yet operating), data reviewed for unusual patterns (not in place) and independent review of procurement (partly in place).<br>Answered by Procurement and Risk and investigations. | Patterns such as splitting or duplicates go unseen. | Set out, not yet operating<br>FR13, C27, C26, C24, C25 |
| F15<br>S41 | **Variations inflate the agreed value**<br>Third parties and supply chain<br>CONTROL REPORTED AS A GAP | Variations approved first: reported as not in place. Related practices also reported weaker: written supplier contracts (partly in place), contract register (not in place) and large variations escalated (set out, not yet operating).<br>Answered by Procurement. | Extra scope or rates are approved after the work is done. | Not in place<br>FR14, C29, C31, C28, C30 |
| F16<br>S42 | **Salaries are redirected through a fake bank change**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Bank changes confirmed with employee: bank detail changes are made as requested.<br>Answered by the respondent. | A request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast. | Not in place<br>FR15, C32 |
| F17<br>S43 | **Ghost employees are paid**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Payroll reviewed by another person: someone else looks at totals, but not the detail. Related practices also reported weaker: headcount verification done (not in place) and independent review of payroll (partly in place).<br>Answered by the respondent and HR and payroll. | Fictitious or departed people stay on the payroll. A payroll that nobody independent reviews before payment is where ghost employees hide. | Partly in place<br>1 answer outstanding<br>FR16, C33, C34, C35 |
| F18<br>S44 | **Leavers stay on the payroll**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Leavers removed before next run: removal is checked for some leavers.<br>Answered by the respondent. | A leaver keeps being paid, often to an account someone else controls. Leavers who stay on the payroll are the commonest ghost employees. | Partly in place<br>FR17, C36 |
| F19<br>S45 | **A false identity enters at hiring**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Identity verified: ID documents are checked by eye for some appointments. Related practices also reported weaker: qualifications verified (partly in place).<br>Answered by the respondent and HR and payroll. | Someone is employed under a stolen or invented identity or false qualifications. False identities enter at hiring and are hard to remove afterwards. | Partly in place<br>FR18, C37, C38 |
| F20<br>S46 | **A stand-in or deepfake candidate is appointed**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Remote appointee identity confirmed: some appointments include a further check, depending on the manager.<br>Answered by HR and payroll. | A remote hire is not the person who was interviewed or who does the work. Deepfake and stand-in candidates are now a recorded way into organisations. | Partly in place<br>FR19, C39 |

| REF | SCENARIO | WHAT THE ANSWERS SHOW | HOW IT HAPPENS AND WHY IT MATTERS (METHOD) | DECISION FACTORS |
|---|---|---|---|---|
| F21<br>S47 | **The payroll payment file is altered after approval**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Payment file protected: not in place.<br>Answered by the respondent and HR and payroll. | Account numbers or amounts change between approval and the bank. | Not in place<br>FR20, C40 |
| F22<br>S48 | **Cash wages are stolen or paid to ghosts**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Two people pay out cash: reported as not in place.<br>Answered by the respondent. | Cash pay-outs are not witnessed or reconciled. | Not in place<br>FR21, C41 |
| F23<br>S49 | **Hours and overtime are inflated**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Hours approved by supervisor: reported as set out or agreed but not yet working in practice.<br>Answered by the respondent. | Unworked hours or overtime are approved and paid. | Set out, not yet operating<br>FR22, C42 |
| F24<br>S50 | **Expenses and advances are abused**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Claims approved by a manager: reported in place only in some areas, cases or periods.<br>Answered by the respondent. | False or inflated claims are paid. | Partly in place<br>FR23, C43 |
| F25<br>S51 | **Labour brokers invoice for workers who were not there**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Broker invoices against attendance: reported as not in place.<br>Answered by the respondent. | Broker or casual worker numbers are inflated. | Not in place<br>FR24, C44 |
| F26<br>S52 | **An insider in a high-risk role works unchecked**<br>People, payroll and insider risk<br>CONTROL REPORTED AS A GAP | Block leave required: most people in sensitive roles take block leave, with someone else doing their work. Related practices also reported weaker: high-risk roles identified (partly in place), no conflicting duties when covering (set out, not yet operating), no single point of knowledge (set out, not yet operating), concerns raised fairly (not in place) and support for financial pressure (not in place).<br>Answered by HR and payroll and the respondent. | Someone who never hands over work conceals an ongoing fraud. | Partly in place<br>FR25, C48, C45, C46, C47, C49, C50 |
| F27<br>S65 | **Refunds are stolen**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Refunds approved independently: approval is sought only for large refunds or when staff are unsure. Related practices also reported weaker: returns received before credit (not in place), refund patterns reviewed (partly in place), post-period reversals reviewed (partly in place) and claim evidence checked for AI (not in place).<br>Answered by Operations and sales. | One person raises and approves refunds or credit notes to themselves or accomplices. Refunds processed and approved by one person are a classic way to steal. | Partly in place<br>1 answer outstanding<br>FR26, C51, C52, C53, C54, C55 |
| F28<br>S66 | **Customer details are changed to divert money or goods**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Customer detail changes verified: most changes are verified with the customer, but sales staff can still make them. Related practices also reported weaker: defined onboarding (not in place), business customers verified (partly in place) and shared details flagged (not in place).<br>Answered by Operations and sales and the respondent. | Refund accounts, delivery addresses or contact numbers are changed without the customer. Changed customer details are how refunds and goods are redirected. | Partly in place<br>FR27, C58, C56, C57, C59 |
| F29<br>S67 | **Credit is obtained with fabricated documents**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Application documents verified: documents are checked only if something looks wrong. Related practices also reported weaker: credit approved independently (partly in place), bureau and fraud database checks (partly in place), early defaults investigated (partly in place), limit and terms changes approved (set out, not yet operating) and statements sent from the system (not in place).<br>Answered by Finance and the respondent. | Fake payslips and bank statements, now easy to generate, secure credit that is never repaid. Application fraud with fabricated documents drives credit losses. | Partly in place<br>1 answer outstanding<br>FR28, C61, C60, C62, C63, C64, C65 |
| F30<br>S68 | **Claims are fabricated or inflated**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Fraud indicators screened: assessors rely on their own experience, without set indicators.<br>Answered by Operations and sales. | False warranty, guarantee or insurance claims are paid. Claims fraud is the main fraud risk for organisations that pay claims. | Partly in place<br>FR29, C66 |
| F31<br>S69 | **Sales are not billed or receipts are diverted**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Everything supplied is billed: billing depends on staff remembering.<br>Answered by Finance. | Goods or services are provided without an invoice, or payments are taken off the books. | Partly in place<br>FR30, C67 |

| REF | SCENARIO | WHAT THE ANSWERS SHOW | HOW IT HAPPENS AND WHY IT MATTERS (METHOD) | DECISION FACTORS |
|---|---|---|---|---|
| F32<br>S70 | **Customers pay fraudsters impersonating the organisation**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Customers warned about payment redirection: the bank account appears on invoices, but there is no warning about changes.<br>Answered by the respondent. | Customers receive fake banking details and pay the wrong account. | Partly in place<br>FR31, C68 |
| F33<br>S71 | **Prices are overridden or side deals made**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Non-standard prices approved: reported as not in place.<br>Answered by the respondent. | Discounts or terms favour a customer in return for a kickback. | Not in place<br>FR32, C69 |
| F34<br>S72 | **Agents report fictitious sales**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Agent sales verified: reported as not in place.<br>Answered by Operations and sales. | Commission is paid on customers who do not exist or soon cancel. | Not in place<br>FR33, C70 |
| F35<br>S73 | **Vouchers and loyalty points are abused**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Vouchers controlled in the system: reported as set out or agreed but not yet working in practice.<br>Answered by Operations and sales. | Staff issue or redeem value to themselves or associates. | Set out, not yet operating<br>FR34, C71 |
| F36<br>S74 | **Customers are wrongly blocked on a fraud flag**<br>Customers, revenue and products<br>CONTROL REPORTED AS A GAP | Human review before a customer is blocked: reported in place only in some areas, cases or periods.<br>Answered by the respondent. | An automated flag is treated as proof and a customer is penalised without review. | Partly in place<br>FR35, C72 |
| F37<br>S75 | **Cash takings are stolen**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Daily reconciliation: takings are reconciled occasionally, or only when there is a shortage.<br>Answered by the respondent. | Takings are under-recorded or removed before banking. Daily reconciliation of takings is the main control over cash theft. | Partly in place<br>FR36, C73 |
| F38<br>S76 | **Stock is stolen and hidden in the counts**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Independent blind counts: the stores team counts, and someone else glances at the results. Related practices also reported weaker: how stock is recorded (not in place), full counts (partly in place), differences explained before adjusting (not in place), write-offs approved and supervised (not in place) and shrinkage tracked (set out, not yet operating).<br>Answered by Operations and sales, Finance and the respondent. | The people who hold stock also count it. Counts done by the people who hold the stock can hide its theft. | Partly in place<br>FR37, C75, C79, C74, C76, C77, C78 |
| F39<br>S78 | **Data leaves on disposed or reissued devices**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Devices wiped before disposal: reported in place only in some areas, cases or periods.<br>Answered by the respondent. | Devices are sold, reissued or returned without being wiped. | Partly in place<br>FR38, C80 |
| F40<br>S79 | **Assets or scrap are sold off cheaply or without payment**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Paid before collection: payment is confirmed in the bank for larger sales only.<br>Answered by Finance. | Disposals favour insiders or goods leave before payment. | Partly in place<br>FR39, C81 |
| F41<br>S80 | **Goods are released to an impostor**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Changed collection instructions verified: reported in place only in some areas, cases or periods.<br>Answered by the respondent. | A changed delivery or collection instruction sends goods to a fraudster. | Partly in place<br>FR40, C82 |
| F42<br>S81 | **Fuel and fleet are misused**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Fuel matched to distance: fuel purchases are not compared with vehicle use.<br>Answered by the respondent. | Fuel cards or vehicles are used privately or fraudulently. | Not in place<br>FR41, C83 |
| F43<br>S82 | **Goods go missing in transit**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Dispatch matched to orders: reported as not in place.<br>Answered by the respondent. | Loads are short-delivered or diverted. | Not in place<br>FR42, C84 |
| F44<br>S83 | **High-value materials are stolen by organised groups**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Organised theft assessed: reported as not in place.<br>Answered by the respondent. | Copper, cable, fuel or similar are stolen with insider help. | Not in place<br>FR43, C85 |
| F45<br>S84 | **Losses are never tracked**<br>Assets, cash and inventory<br>CONTROL REPORTED AS A GAP | Losses tracked and reported: reported as set out or agreed but not yet working in practice.<br>Answered by the respondent. | Shrinkage and losses are written off without analysis. | Set out, not yet operating<br>FR44, C86 |

| REF | SCENARIO | WHAT THE ANSWERS SHOW | HOW IT HAPPENS AND WHY IT MATTERS (METHOD) | DECISION FACTORS |
|---|---|---|---|---|
| F46<br>S85 | **An email account is taken over**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Multi-factor on all email: email accounts are protected by passwords only.<br>Answered by the respondent. | A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication. | Not in place<br>FR45, C87 |
| F47<br>S86 | **A payment instruction received by email is acted on**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Email never enough on its own: payment changes received by email are acted on as received.<br>Answered by IT and information. | Changed details or urgent payments are processed on the strength of an email. Acting on payment instructions received by email is how business email compromise succeeds. | Not in place<br>FR46, C88 |
| F48<br>S87 | **A cloned voice or video instruction is obeyed**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Verification for calls, voice notes and video: some staff check unusual requests, depending on their own judgement. Related practices also reported weaker: changes to call-back details verified (partly in place) and executives and their teams prepared (partly in place).<br>Answered by the respondent and Finance. | A caller who sounds or looks like a known person is believed. Voices and faces can be cloned, so only an agreed verification method holds. | Partly in place<br>FR47, C89, C91, C90 |
| F49<br>S88 | **Customer accounts are taken over**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Customer logins protected: multi-factor authentication is offered, but customers can opt out.<br>Answered by the respondent. | Stolen passwords or SIM swaps are used to drain customer accounts. Customer accounts without takeover protection are drained with stolen passwords. | Partly in place<br>FR48, C92 |
| F50<br>S89 | **A security compromise is not notified**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Compromises reported as POPIA requires: a compromise would be handled as it happens, without a set process. Related practices also reported weaker: affected people warned (not in place).<br>Answered by IT and information. | The Regulator and affected people are not told, so they cannot protect themselves. POPIA section 22 requires notification as soon as reasonably possible. | Partly in place<br>FR49, C93, C94 |
| F51<br>S90 | **A help desk reset hands an attacker access**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Help desk resets verified: most resets need verification through a trusted route, such as the person's manager or a number on file.<br>Answered by IT and information. | An impersonator persuades the help desk to reset a password or authenticator. | Partly in place<br>FR50, C95 |
| F52<br>S91 | **Systems that move money are accessed without strong sign-in**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Multi-factor on critical systems: these systems are protected by passwords only.<br>Answered by IT and information. | Remote access, cloud or banking systems rely on passwords alone. | Not in place<br>FR51, C96 |
| F53<br>S92 | **Personal information is over-exposed or kept too long**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Access to personal information limited: access is limited for some systems only.<br>Answered by IT and information. | Too many people can reach or export personal information, or records outlive their purpose. | Partly in place<br>FR52, C97 |
| F54<br>S93 | **A SIM swap defeats one-time PIN approvals**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Approval numbers protected: staff have been told about SIM swaps, but nothing has been changed.<br>Answered by IT and information. | Approvals sent by SMS are intercepted. | Partly in place<br>FR53, C98 |
| F55<br>S94 | **An AI assistant is manipulated by hidden instructions**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Assistant permissions limited: reported in place only in some areas, cases or periods.<br>Answered by IT and information. | Instructions planted in emails or documents make an assistant leak data or act. | Partly in place<br>FR54, C99 |
| F56<br>S95 | **The organisation's own information helps attackers**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Staff guided on what not to share: reported as not in place.<br>Answered by IT and information. | Published staff details and routines make impersonation easier. | Not in place<br>FR55, C100 |
| F57<br>S96 | **A compromise is not contained quickly**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Compromise playbook: there is no plan; each case would be handled from scratch.<br>Answered by IT and information. | Accounts stay compromised while suppliers and customers keep receiving instructions. | Not in place<br>FR56, C101 |
| F58<br>S97 | **The organisation is impersonated to defraud others**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Brand impersonation monitored and removed: reported as not in place.<br>Answered by IT and information. | Fake websites, accounts or job adverts in the organisation's name collect money or personal information. | Not in place<br>FR57, C102 |

| REF | SCENARIO | WHAT THE ANSWERS SHOW | HOW IT HAPPENS AND WHY IT MATTERS (METHOD) | DECISION FACTORS |
|---|---|---|---|---|
| F59<br>S98 | **Spoofed email in the organisation's name deceives staff, suppliers or customers**<br>Digital, cyber-enabled and identity fraud<br>CONTROL REPORTED AS A GAP | Domain protected against spoofing: partly in place.<br>Answered by IT and information. | Emails that appear to come from the organisation's own domain carry false payment instructions. | Partly in place<br>FR58, C103 |

APPENDIX B

# Fraud risk register

One risk for each scenario with a control reported as a gap or answers to settle. No likelihood, impact, priority or monetary value is assigned: MK has not yet approved a method for rating them.

| REF | RISK | CURRENT POSITION | TREATMENT | OWNER |
|---|---|---|---|---|
| FR01 F02 | **A payment to a cause linked to a decision-maker buys influence, because recipients checked for links is partly in place.** Not rated. | Recipients checked for links: reported in place only in some areas, cases or periods. | C02 Recipients checked for links | Ethics lead |
| FR02 F03 | **An insider or outsider adds a supplier that does not exist and invoices it, because new supplier process is partly in place.** Fictitious suppliers enter through onboarding that can be skipped. Not rated. | Checks happen only when someone thinks to do them. | C03 New supplier process; C04 Directors identified; C05 Directors compared with staff; C06 Suppliers re-checked; C07 Dormant suppliers deactivated | Procurement lead |
| FR03 F04 | **A fraudster, often impersonating the supplier by email, voice or video, has the bank account changed, because change confirmed with supplier is partly in place and familiar caller still verified is not in place.** Changed supplier bank details are the most common route for payment fraud, and cloned voices now defeat call-backs that rely on recognition. Not rated. | Changes are confirmed, but sometimes using contact details taken from the request itself. A follow-up call from the 'supplier' is accepted as confirmation. | C08 Change confirmed with supplier; C09 Familiar caller still verified | Finance lead |
| FR04 F05 | **Payments go to an employee's or fraudster's account from the first invoice, because bank account verified is partly in place.** Confirming account ownership at onboarding stops both fictitious and impersonated suppliers being paid into accounts they do not own; added after the review's isolated-weakness probe. Not rated. | Accounts are verified through a bank or third-party service for most new suppliers. | C10 Bank account verified | Procurement lead |
| FR05 F06 | **A buyer invents or inflates a purchase and approves its payment, because orderer is not payment approver is not in place.** One person who can both order and approve payment can pay a supplier they invented. Not rated. | The same person can order and approve payment. | C11 Orderer is not payment approver | Procurement lead |
| FR06 F07 | **Overbilling, fictitious deliveries or inflated rates are paid, because three-way match is not in place.** Invoices paid without checking approval and receipt are how overbilling and fictitious deliveries get paid. Not rated. | Invoices are paid without being checked against what was approved or received. | C16 Three-way match; C12 Approved order before commitment; C13 Receipt recorded before payment; C14 Quantities checked; C15 Services confirmed | Finance lead |
| FR07 F08 | **A provider that handles money, customers or data has wider access than the service needs, because provider access limited is partly in place.** Provider access wider than the service needs is how outsourced processes are abused; now applies wherever processes are outsourced, not only where nothing is bought. Not rated. | Access is limited to what the service needs for the main providers. | C17 Provider access limited | Procurement lead |
| FR08 F09 | **One person releases a payment run, because two approvers on banking platform is partly in place.** Not rated. | A second approval happens sometimes. | C18 Two approvers on banking platform | Finance lead |
| FR09 F10 | **Specifications, evaluation or thresholds are bent towards a chosen supplier, because evaluation against set criteria is partly in place.** Not rated. | Criteria exist, but they are sometimes set or changed after bids arrive. | C20 Evaluation against set criteria; C19 Quote and tender thresholds | Procurement lead |

| REF | RISK | CURRENT POSITION | TREATMENT | OWNER |
|---|---|---|---|---|
| FR10 F11 | **A long-standing buyer-supplier relationship hides favours, because annual interest declarations is not in place.** Not rated. | Buying staff do not declare interests. | C21 Annual interest declarations | Legal and compliance lead |
| FR11 F12 | **Personal purchases or split transactions go unreviewed, because independent reconciliation is not in place.** Not rated. | Independent reconciliation: reported as not in place. | C22 Independent reconciliation | Finance lead |
| FR12 F13 | **Agents act improperly or bill for work not done, because intermediaries vetted is not in place.** Not rated. | Intermediaries vetted: reported as not in place. | C23 Intermediaries vetted | Procurement lead |
| FR13 F14 | **Patterns such as splitting or duplicates go unseen, because senior review of supplier payments is set out, not yet operating.** Not rated. | Senior review of supplier payments: reported as set out or agreed but not yet working in practice. | C27 Senior review of supplier payments; C26 Split orders monitored; C24 Data reviewed for unusual patterns; C25 Independent review of procurement | Finance lead |
| FR14 F15 | **Extra scope or rates are approved after the work is done, because variations approved first is not in place.** Not rated. | Variations approved first: reported as not in place. | C29 Variations approved first; C31 Written supplier contracts; C28 Contract register; C30 Large variations escalated | Procurement lead |
| FR15 F16 | **A request that appears to come from an employee changes where their salary is paid, because bank changes confirmed with employee is not in place.** Salary redirection through fake bank change requests is common and fast. Not rated. | Bank detail changes are made as requested. | C32 Bank changes confirmed with employee | HR and payroll lead |
| FR16 F17 | **Fictitious or departed people stay on the payroll, because payroll reviewed by another person is partly in place.** A payroll that nobody independent reviews before payment is where ghost employees hide. Not rated. | Someone else looks at totals, but not the detail. | C33 Payroll reviewed by another person; C34 Headcount verification done; C35 Independent review of payroll | HR and payroll lead |
| FR17 F18 | **A leaver keeps being paid, often to an account someone else controls, because leavers removed before next run is partly in place.** Leavers who stay on the payroll are the commonest ghost employees. Not rated. | Removal is checked for some leavers. | C36 Leavers removed before next run | HR and payroll lead |
| FR18 F19 | **Someone is employed under a stolen or invented identity or false qualifications, because identity verified is partly in place.** False identities enter at hiring and are hard to remove afterwards. Not rated. | ID documents are checked by eye for some appointments. | C37 Identity verified; C38 Qualifications verified | HR and payroll lead |
| FR19 F20 | **A remote hire is not the person who was interviewed or who does the work, because remote appointee identity confirmed is partly in place.** Deepfake and stand-in candidates are now a recorded way into organisations. Not rated. | Some appointments include a further check, depending on the manager. | C39 Remote appointee identity confirmed | HR and payroll lead |
| FR20 F21 | **Account numbers or amounts change between approval and the bank, because payment file protected is not in place.** Not rated. | Payment file protected: not in place. | C40 Payment file protected | HR and payroll lead |
| FR21 F22 | **Cash pay-outs are not witnessed or reconciled, because two people pay out cash is not in place.** Not rated. | Two people pay out cash: reported as not in place. | C41 Two people pay out cash | Finance lead |
| FR22 F23 | **Unworked hours or overtime are approved and paid, because hours approved by supervisor is set out, not yet operating.** Not rated. | Hours approved by supervisor: reported as set out or agreed but not yet working in practice. | C42 Hours approved by supervisor | HR and payroll lead |

| REF | RISK | CURRENT POSITION | TREATMENT | OWNER |
|---|---|---|---|---|
| FR23 F24 | **False or inflated claims are paid, because claims approved by a manager is partly in place.** Not rated. | Claims approved by a manager: reported in place only in some areas, cases or periods. | C43 Claims approved by a manager | Finance lead |
| FR24 F25 | **Broker or casual worker numbers are inflated, because broker invoices against attendance is not in place.** Not rated. | Broker invoices against attendance: reported as not in place. | C44 Broker invoices against attendance | Operations lead |
| FR25 F26 | **Someone who never hands over work conceals an ongoing fraud, because block leave required is partly in place.** Not rated. | Most people in sensitive roles take block leave, with someone else doing their work. | C48 Block leave required; C45 High-risk roles identified; C46 No conflicting duties when covering; C47 No single point of knowledge; C49 Concerns raised fairly; C50 Support for financial pressure | HR and payroll lead |
| FR26 F27 | **One person raises and approves refunds or credit notes to themselves or accomplices, because refunds approved independently is partly in place.** Refunds processed and approved by one person are a classic way to steal. Not rated. | Approval is sought only for large refunds or when staff are unsure. | C51 Refunds approved independently; C52 Returns received before credit; C53 Refund patterns reviewed; C54 Post-period reversals reviewed; C55 Claim evidence checked for AI | Commercial and customer lead |
| FR27 F28 | **Refund accounts, delivery addresses or contact numbers are changed without the customer, because customer detail changes verified is partly in place.** Changed customer details are how refunds and goods are redirected. Not rated. | Most changes are verified with the customer, but sales staff can still make them. | C58 Customer detail changes verified; C56 Defined onboarding; C57 Business customers verified; C59 Shared details flagged | Commercial and customer lead |
| FR28 F29 | **Fake payslips and bank statements, now easy to generate, secure credit that is never repaid, because application documents verified is partly in place.** Application fraud with fabricated documents drives credit losses. Not rated. | Documents are checked only if something looks wrong. | C61 Application documents verified; C60 Credit approved independently; C62 Bureau and fraud database checks; C63 Early defaults investigated; C64 Limit and terms changes approved; C65 Statements sent from the system | Finance lead |
| FR29 F30 | **False warranty, guarantee or insurance claims are paid, because fraud indicators screened is partly in place.** Claims fraud is the main fraud risk for organisations that pay claims. Not rated. | Assessors rely on their own experience, without set indicators. | C66 Fraud indicators screened | Commercial and customer lead |
| FR30 F31 | **Goods or services are provided without an invoice, or payments are taken off the books, because everything supplied is billed is partly in place.** Not rated. | Billing depends on staff remembering. | C67 Everything supplied is billed | Finance lead |
| FR31 F32 | **Customers receive fake banking details and pay the wrong account, because customers warned about payment redirection is partly in place.** Not rated. | The bank account appears on invoices, but there is no warning about changes. | C68 Customers warned about payment redirection | Finance lead |
| FR32 F33 | **Discounts or terms favour a customer in return for a kickback, because non-standard prices approved is not in place.** Not rated. | Non-standard prices approved: reported as not in place. | C69 Non-standard prices approved | Commercial and customer lead |
| FR33 F34 | **Commission is paid on customers who do not exist or soon cancel, because agent sales verified is not in place.** Not rated. | Agent sales verified: reported as not in place. | C70 Agent sales verified | Commercial and customer lead |
| FR34 F35 | **Staff issue or redeem value to themselves or associates, because vouchers controlled in the system is set out, not yet operating.** Not rated. | Vouchers controlled in the system: reported as set out or agreed but not yet working in practice. | C71 Vouchers controlled in the system | Commercial and customer lead |

| REF | RISK | CURRENT POSITION | TREATMENT | OWNER |
|---|---|---|---|---|
| FR35 F36 | **An automated flag is treated as proof and a customer is penalised without review, because human review before a customer is blocked is partly in place.** Not rated. | Human review before a customer is blocked: reported in place only in some areas, cases or periods. | C72 Human review before a customer is blocked | Fraud risk lead |
| FR36 F37 | **Takings are under-recorded or removed before banking, because daily reconciliation is partly in place.** Daily reconciliation of takings is the main control over cash theft. Not rated. | Takings are reconciled occasionally, or only when there is a shortage. | C73 Daily reconciliation | Operations lead |
| FR37 F38 | **The people who hold stock also count it, because independent blind counts is partly in place.** Counts done by the people who hold the stock can hide its theft. Not rated. | The stores team counts, and someone else glances at the results. | C75 Independent blind counts; C79 How stock is recorded; C74 Full counts; C76 Differences explained before adjusting; C77 Write-offs approved and supervised; C78 Shrinkage tracked | Finance lead |
| FR38 F39 | **Devices are sold, reissued or returned without being wiped, because devices wiped before disposal is partly in place.** Not rated. | Devices wiped before disposal: reported in place only in some areas, cases or periods. | C80 Devices wiped before disposal | IT lead |
| FR39 F40 | **Disposals favour insiders or goods leave before payment, because paid before collection is partly in place.** Not rated. | Payment is confirmed in the bank for larger sales only. | C81 Paid before collection | Finance lead |
| FR40 F41 | **A changed delivery or collection instruction sends goods to a fraudster, because changed collection instructions verified is partly in place.** Not rated. | Changed collection instructions verified: reported in place only in some areas, cases or periods. | C82 Changed collection instructions verified | Operations lead |
| FR41 F42 | **Fuel cards or vehicles are used privately or fraudulently, because fuel matched to distance is not in place.** Not rated. | Fuel purchases are not compared with vehicle use. | C83 Fuel matched to distance | Operations lead |
| FR42 F43 | **Loads are short-delivered or diverted, because dispatch matched to orders is not in place.** Not rated. | Dispatch matched to orders: reported as not in place. | C84 Dispatch matched to orders | Operations lead |
| FR43 F44 | **Copper, cable, fuel or similar are stolen with insider help, because organised theft assessed is not in place.** Not rated. | Organised theft assessed: reported as not in place. | C85 Organised theft assessed | Operations lead |
| FR44 F45 | **Shrinkage and losses are written off without analysis, because losses tracked and reported is set out, not yet operating.** Not rated. | Losses tracked and reported: reported as set out or agreed but not yet working in practice. | C86 Losses tracked and reported | Finance lead |
| FR45 F46 | **A mailbox without strong sign-in is used to send or intercept payment instructions, because multi-factor on all email is not in place.** Most business email compromise starts with an account that has no multi-factor authentication. Not rated. | Email accounts are protected by passwords only. | C87 Multi-factor on all email | IT lead |
| FR46 F47 | **Changed details or urgent payments are processed on the strength of an email, because email never enough on its own is not in place.** Acting on payment instructions received by email is how business email compromise succeeds. Not rated. | Payment changes received by email are acted on as received. | C88 Email never enough on its own | Chief financial officer |
| FR47 F48 | **A caller who sounds or looks like a known person is believed, because verification for calls, voice notes and video is partly in place.** Voices and faces can be cloned, so only an agreed verification method holds. Not rated. | Some staff check unusual requests, depending on their own judgement. | C89 Verification for calls, voice notes and video; C91 Changes to call-back details verified; C90 Executives and their teams prepared | Chief financial officer |

| REF | RISK | CURRENT POSITION | TREATMENT | OWNER |
|---|---|---|---|---|
| FR48 F49 | **Stolen passwords or SIM swaps are used to drain customer accounts, because customer logins protected is partly in place.** Customer accounts without takeover protection are drained with stolen passwords. Not rated. | Multi-factor authentication is offered, but customers can opt out. | C92 Customer logins protected | IT lead |
| FR49 F50 | **The Regulator and affected people are not told, so they cannot protect themselves, because compromises reported as POPIA requires is partly in place.** POPIA section 22 requires notification as soon as reasonably possible. Not rated. | A compromise would be handled as it happens, without a set process. | C93 Compromises reported as POPIA requires; C94 Affected people warned | IT lead |
| FR50 F51 | **An impersonator persuades the help desk to reset a password or authenticator, because help desk resets verified is partly in place.** Not rated. | Most resets need verification through a trusted route, such as the person's manager or a number on file. | C95 Help desk resets verified | IT lead |
| FR51 F52 | **Remote access, cloud or banking systems rely on passwords alone, because multi-factor on critical systems is not in place.** Not rated. | These systems are protected by passwords only. | C96 Multi-factor on critical systems | IT lead |
| FR52 F53 | **Too many people can reach or export personal information, or records outlive their purpose, because access to personal information limited is partly in place.** Not rated. | Access is limited for some systems only. | C97 Access to personal information limited | Legal and compliance lead |
| FR53 F54 | **Approvals sent by SMS are intercepted, because approval numbers protected is partly in place.** Not rated. | Staff have been told about SIM swaps, but nothing has been changed. | C98 Approval numbers protected | IT lead |
| FR54 F55 | **Instructions planted in emails or documents make an assistant leak data or act, because assistant permissions limited is partly in place.** Not rated. | Assistant permissions limited: reported in place only in some areas, cases or periods. | C99 Assistant permissions limited | IT lead |
| FR55 F56 | **Published staff details and routines make impersonation easier, because staff guided on what not to share is not in place.** Not rated. | Staff guided on what not to share: reported as not in place. | C100 Staff guided on what not to share | Commercial and customer lead |
| FR56 F57 | **Accounts stay compromised while suppliers and customers keep receiving instructions, because compromise playbook is not in place.** Not rated. | There is no plan; each case would be handled from scratch. | C101 Compromise playbook | IT lead |
| FR57 F58 | **Fake websites, accounts or job adverts in the organisation's name collect money or personal information, because brand impersonation monitored and removed is not in place.** Not rated. | Brand impersonation monitored and removed: reported as not in place. | C102 Brand impersonation monitored and removed | Chief financial officer |
| FR58 F59 | **Emails that appear to come from the organisation's own domain carry false payment instructions, because domain protected against spoofing is partly in place.** Not rated. | Domain protected against spoofing: partly in place. | C103 Domain protected against spoofing | IT lead |

APPENDIX C

# Control blueprint register

Each control once, with every scenario it serves, grouped by what is to be done and then in the method's order. "Reported today" is what the organisation answered; the target practice, activities, records, measure and failure response come from MK's draft control-content library (control-content-library-0.1), which is advisory content and not approved. The method's own wording and source references for each control are in the supporting workbook.

## PUT IN PLACE · 59

### C02 Recipients checked for links

ETHICS LEAD · S26

**REPORTED TODAY**
Recipients checked for links: reported in place only in some areas, cases or periods.

**TARGET OPERATING PRACTICE**
Before any donation or sponsorship is committed, the recipient is checked for links to public officials, customers' decision-makers and employees, and any link found is disclosed and approved.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for donations and sponsorships: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each donation or sponsorship.
3. Look back over donations and sponsorships from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E02**
Donation approval file
Cycle: before each commitment

**SUCCESS MEASURE · M02**
Every donation or sponsorship in the period has a donation approval file showing the link checks completed and approved before money was committed.

**IF IT FAILS**
Where a donation or sponsorship went ahead without the check, complete the check at once and review anything paid or released before it was found.

### C03 New supplier process

PROCUREMENT LEAD · S29

**REPORTED TODAY**
Checks happen only when someone thinks to do them.

**TARGET OPERATING PRACTICE**
Every new supplier passes set checks, including registration, tax number, bank account and directors, and is approved before it can be paid.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for new suppliers: what is checked, by whom, and who may approve an exception.
2. Set the supplier master file so that no new supplier proceeds until the check is recorded as passed.
3. Look back over new suppliers from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E03**
Supplier set-up file
Cycle: before each new supplier is first paid

**SUCCESS MEASURE · M03**
Every new supplier in the period has a supplier set-up file showing each check passed and an approval dated before the first payment.

**IF IT FAILS**
Where a new supplier went ahead without the check, complete the check at once and review anything paid or released before it was found.

### C08 Change confirmed with supplier

FINANCE LEAD · S30

**REPORTED TODAY**
Changes are confirmed, but sometimes using contact details taken from the request itself.

**TARGET OPERATING PRACTICE**
Every change to a supplier's bank details is confirmed with the supplier, using contact details already on file and not those in the request, before it takes effect.

**IMPLEMENTATION ACTIVITIES**

1. Write the confirmation step into the procedure: a call to the supplier on a number already on file, never details supplied with the request.
2. Limit who can make the change in the supplier master file, and log how each change was confirmed.
3. Check the changes to suppliers' bank details made in the last six months against the log, and confirm any that were not verified.

**RECORDS TO KEEP · E08**
Bank detail change log
Cycle: whenever a change is requested

**SUCCESS MEASURE · M08**
Every change to a supplier's bank details made in the period was confirmed with the supplier on contact details already on file before it took effect, or is a recorded and approved exception.

**IF IT FAILS**
Suspend any change to a supplier's bank details that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

## C09 **Familiar caller still verified**

FINANCE LEAD · S30

**REPORTED TODAY**

A follow-up call from the 'supplier' is accepted as confirmation.

**TARGET OPERATING PRACTICE**

A call back on the number on file is required for every change request, whatever an incoming call or video appears to show, and staff know why.

**IMPLEMENTATION ACTIVITIES**

1. Write the rule and have it approved by the chief financial officer.
2. Brief staff who process changes to supplier details, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

**RECORDS TO KEEP · E09**

Verification rule record
Cycle: each year

**SUCCESS MEASURE · M09**

All staff who process changes to supplier details were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including a call or video that appeared to come from the supplier's usual contact.

**IF IT FAILS**

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

## C10 **Bank account verified**

PROCUREMENT LEAD · S31

**REPORTED TODAY**

Accounts are verified through a bank or third-party service for most new suppliers.

**TARGET OPERATING PRACTICE**

Every new supplier's bank account is verified as belonging to the supplier, through a bank or third-party verification service, before the first payment.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for new suppliers: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each new supplier.
3. Look back over new suppliers from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E10**

Account verification result
Cycle: before each new supplier is first paid

**SUCCESS MEASURE · M10**

Every new supplier in the period has an account verification result showing the account verified through a bank or third-party service before the first payment.

**IF IT FAILS**

Where a new supplier went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C11 **Orderer is not payment approver**

PROCUREMENT LEAD · S32

**REPORTED TODAY**

The same person can order and approve payment. (answered by Procurement)

**TARGET OPERATING PRACTICE**

The person who places an order never approves the related supplier payment, and any exception is approved and recorded.

**IMPLEMENTATION ACTIVITIES**

1. List who holds the duties concerned, and remove any combination that lets one person place an order and approve its payment.
2. Set the purchasing and payment systems so that the combination cannot be granted again without recorded approval.
3. Review the combinations at least once a year and whenever roles change, including temporary cover.

**RECORDS TO KEEP · E11**

Access and delegation list
Cycle: each year

**SUCCESS MEASURE · M11**

The review for the period found no one able to place an order and approve its payment, other than approved and recorded exceptions.

**IF IT FAILS**

Remove the combination, review the orders and payments handled while it existed, and record the outcome.

## C16 **Three-way match**

FINANCE LEAD · S33

**REPORTED TODAY**

Invoices are paid without being checked against what was approved or received. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every invoice is checked against an approved order, quote or contract and against confirmation of receipt before payment, and differences are resolved first.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for invoices: what is checked, by whom, and who may approve an exception.
2. Set the payment system so that no invoice proceeds until the check is recorded as passed.
3. Look back over invoices from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E16**

Payment file
Cycle: before each payment

**SUCCESS MEASURE · M16**

Every invoice in the period has a payment file showing a match to an approval and to a confirmation of receipt before payment.

**IF IT FAILS**

Where an invoice went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C17 **Provider access limited**

PROCUREMENT LEAD · S34

**REPORTED TODAY**

Access is limited to what the service needs for the main providers.

**TARGET OPERATING PRACTICE**

Every outsourced provider's access to systems, money or data is limited to what the service needs, logged and reviewed at least once a year.

**IMPLEMENTATION ACTIVITIES**

1. List every provider with access in scope and how it is set today.
2. Apply the setting to each, starting with providers with access to payments or personal information, and record any approved exception.
3. Produce the provider access register each year, and follow up any gap.

**RECORDS TO KEEP · E17**

Provider access register
Cycle: each year

**SUCCESS MEASURE · M17**

At the end of the period, the provider access register shows every provider's access limited to its service and reviewed within the year, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C18 **Two approvers on banking platform**

FINANCE LEAD · S35

**REPORTED TODAY**

A second approval happens sometimes. (answered by Procurement)

**TARGET OPERATING PRACTICE**

The banking platform requires two separate people to approve every supplier payment.

**IMPLEMENTATION ACTIVITIES**

1. List every payment profile in scope and how it is set today.
2. Apply the setting to each, starting with supplier payment profiles, and record any approved exception.
3. Produce the banking platform approval settings report each quarter, and follow up any gap.

**RECORDS TO KEEP · E18**

Banking platform approval settings report
Cycle: each quarter

**SUCCESS MEASURE · M18**

At the end of the period, the banking platform approval settings report shows two separate approvers required for every supplier payment, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C20 **Evaluation against set criteria**

PROCUREMENT LEAD · S36

**REPORTED TODAY**

Criteria exist, but they are sometimes set or changed after bids arrive. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Every competitive purchase is evaluated by more than one person against criteria set before bids are received, and the scores are recorded.

**IMPLEMENTATION ACTIVITIES**

1. Require evaluation criteria to be approved and recorded before a request for quotation or tender is issued.
2. Appoint at least two evaluators for each purchase, each declaring any conflict of interest.
3. Keep the scoresheets with the decision, and check each quarter that every evaluation file is complete.

**RECORDS TO KEEP · E20**

Evaluation file
Cycle: for each competitive purchase

**SUCCESS MEASURE · M20**

Every competitive purchase in the period has an evaluation file showing criteria dated before bids were received and scores from at least two evaluators.

**IF IT FAILS**

Where a competitive purchase went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C21 **Annual interest declarations**

LEGAL AND COMPLIANCE LEAD · S37

**REPORTED TODAY**

Buying staff do not declare interests. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Everyone involved in buying declares their business interests and relationships each year and when circumstances change, and the declarations are kept on record.

**IMPLEMENTATION ACTIVITIES**

1. Set the requirement in writing, including which people involved in buying it applies to and who may approve an exception.
2. Apply it each year and when circumstances change, and record each case and each approved exception.
3. Report coverage and exceptions to the accountable executive at least once a year.

**RECORDS TO KEEP · E21**

Declarations register
Cycle: each year and when circumstances change

**SUCCESS MEASURE · M21**

Every person involved in buying in scope made a declaration in the year, or has an approved exception.

**IF IT FAILS**

Where the requirement is not met, record why, agree a corrective action with a date and report it to the accountable executive.

## C22 Independent reconciliation

FINANCE LEAD · S38

**REPORTED TODAY**

Independent reconciliation: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Each card statement is reconciled to receipts and reviewed monthly by someone other than the cardholder, and every unsupported transaction is followed up.

**IMPLEMENTATION ACTIVITIES**

1. Set the reconciliation: what is compared, how often (monthly), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

**RECORDS TO KEEP · E22**

Card statement reconciliation
Cycle: monthly

**SUCCESS MEASURE · M22**

Every card statement reconciliation due in the period was completed and reviewed, and every difference was supported or followed up to a recorded conclusion.

**IF IT FAILS**

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

## C23 Intermediaries vetted

PROCUREMENT LEAD · S39

**REPORTED TODAY**

Intermediaries vetted: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Every intermediary, such as an agent, consultant or broker, is vetted before appointment, including who owns it, its reputation and any links to public officials, and the appointment is approved.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for intermediaries: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each intermediary.
3. Look back over intermediaries from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E23**

Intermediary due diligence file
Cycle: before each appointment

**SUCCESS MEASURE · M23**

Every intermediary in the period has an intermediary due diligence file showing the due diligence completed and the appointment approved before engagement.

**IF IT FAILS**

Where an intermediary went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C27 Senior review of supplier payments

FINANCE LEAD · S40

**REPORTED TODAY**

Senior review of supplier payments: reported as set out or agreed but not yet working in practice. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Each month a senior manager who does not process payments reviews the list of supplier payments for unfamiliar suppliers, unusual amounts and changed bank details, and follows up each query.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in supplier payments and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E27**

Monthly payment review
Cycle: monthly

**SUCCESS MEASURE · M27**

The review of supplier payments ran monthly throughout the period, and every exception it raised has a recorded answer.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C29 Variations approved first

PROCUREMENT LEAD · S41

**REPORTED TODAY**

Variations approved first: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Every change to agreed work, such as a variation, extension or extra scope, is approved by someone with the authority to do so before the work goes ahead, whether or not there is a written contract.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve variations, within what limits, and confirm that no one approves their own.
2. Record the approver on each variation, and check that it is never the person who processed it.
3. Review a recent month of variations for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E29**

Variation approval record
Cycle: before each variation proceeds

**SUCCESS MEASURE · M29**

Every variation in the period was approved by someone other than the person who processed it, before the work went ahead.

**IF IT FAILS**

Have any variation approved by the person who processed it re-approved independently, and review that person's other variations for the period.

### C32 **Bank changes confirmed with employee**

HR AND PAYROLL LEAD · S42

**REPORTED TODAY**

Bank detail changes are made as requested.

**TARGET OPERATING PRACTICE**

Every change to an employee's bank details is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.

**IMPLEMENTATION ACTIVITIES**

1. Write the confirmation step into the procedure: a call to the employee on a number already on file, or in person, never details supplied with the request.
2. Limit who can make the change in the payroll system, and log how each change was confirmed.
3. Check the changes to employees' bank details made in the last six months against the log, and confirm any that were not verified.

**RECORDS TO KEEP · E32**

Bank detail change log
Cycle: whenever a change is requested

**SUCCESS MEASURE · M32**

Every change to an employee's bank details made in the period was confirmed through a channel the organisation started before it took effect, or is a recorded and approved exception.

**IF IT FAILS**

Suspend any change to an employee's bank details that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

### C33 **Payroll reviewed by another person**

HR AND PAYROLL LEAD · S43

**REPORTED TODAY**

Someone else looks at totals, but not the detail.

**TARGET OPERATING PRACTICE**

Every payroll run is reviewed before payment by someone who did not prepare it, and the review is recorded.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve payroll runs, within what limits, and confirm that no one approves their own.
2. Record the approver on each payroll run, and check that it is never the person who processed it.
3. Review a recent month of payroll runs for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E33**

Payroll review checklist
Cycle: each pay run

**SUCCESS MEASURE · M33**

Every payroll run in the period was approved by someone other than the person who processed it, before payment, with variances explained.

**IF IT FAILS**

Have any payroll run approved by the person who processed it re-approved independently, and review that person's other payroll runs for the period.

### C36 **Leavers removed before next run**

HR AND PAYROLL LEAD · S44

**REPORTED TODAY**

Removal is checked for some leavers.

**TARGET OPERATING PRACTICE**

Every leaver is confirmed as removed from payroll before the next pay run, using the HR leaver list.

**IMPLEMENTATION ACTIVITIES**

1. Set the reconciliation: what is compared, how often (each pay run), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

**RECORDS TO KEEP · E35**

Leaver reconciliation
Cycle: each pay run

**SUCCESS MEASURE · M36**

Every leaver reconciliation due in the period was completed and reviewed, and every difference was cleared before the pay run.

**IF IT FAILS**

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

### C37 **Identity verified**

HR AND PAYROLL LEAD · S45

**REPORTED TODAY**

ID documents are checked by eye for some appointments.

**TARGET OPERATING PRACTICE**

Every new employee's identity is verified against Home Affairs records, for example through a verification service, before they start.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for new employees: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each new employee.
3. Look back over new employees from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E36**

Identity verification result
Cycle: before each start date

**SUCCESS MEASURE · M37**

Every new employee in the period has an identity verification result showing identity verified against Home Affairs records before the start date.

**IF IT FAILS**

Where a new employee went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C39 **Remote appointee identity confirmed**

HR AND PAYROLL LEAD · S46

**REPORTED TODAY**

Some appointments include a further check, depending on the manager. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Every remote appointee's identity is confirmed through an in-person meeting, or an identity check designed to resist replayed and injected video, before access and pay are set up, and failed checks are reviewed by a person.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for remote appointees: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each remote appointee.
3. Look back over remote appointees from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E38**

Remote appointment identity record
Cycle: before access and pay are set up

**SUCCESS MEASURE · M39**

Every remote appointee in the period has a remote appointment identity record showing identity confirmed in person, or by a check that resists replayed video, before access and pay were set up.

**IF IT FAILS**

Where a remote appointee went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C40 **Payment file protected**

HR AND PAYROLL LEAD · S47

**REPORTED TODAY**

Payment file protected: not in place. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

The payroll payment file cannot be changed between approval and upload to the bank, through a secure bank connection or a file check that the preparer cannot regenerate.

**IMPLEMENTATION ACTIVITIES**

1. Choose the protection: a secure bank connection, or a file check that the preparer cannot regenerate.
2. Apply it to every payroll payment file before upload.
3. Record the check each pay run, and investigate any mismatch before payment.

**RECORDS TO KEEP · E39**

Payment file control record
Cycle: each pay run

**SUCCESS MEASURE · M40**

At the end of the period, the payment file control record shows the protection applied to every payroll payment file, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C41 **Two people pay out cash**

FINANCE LEAD · S48

**REPORTED TODAY**

Two people pay out cash: reported as not in place.

**TARGET OPERATING PRACTICE**

Cash wages are always paid out by two people together, who both sign the pay-out record.

**IMPLEMENTATION ACTIVITIES**

1. Set the rule that two people pay out cash wages together, and name who may do so.
2. Use a pay-out record that both people sign for each payment.
3. Check the records each pay run for a missing second signature.

**RECORDS TO KEEP · E40**

Cash pay-out record
Cycle: each pay run

**SUCCESS MEASURE · M41**

The review for the period found no one able to pay out cash wages alone, and every pay-out record carries two signatures.

**IF IT FAILS**

Remove the combination, review the cash pay-outs handled while it existed, and record the outcome.

## C42 **Hours approved by supervisor**

HR AND PAYROLL LEAD · S49

**REPORTED TODAY**

Hours approved by supervisor: reported as set out or agreed but not yet working in practice.

**TARGET OPERATING PRACTICE**

Hours and overtime are approved by the employee's supervisor, against the roster or attendance record, before they are paid.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve timesheets, within what limits, and confirm that no one approves their own.
2. Set the time and attendance system so that the person who processes a timesheet cannot approve it.
3. Review a recent month of timesheets for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E41**

Timesheet approval record
Cycle: each pay run

**SUCCESS MEASURE · M42**

Every timesheet paid in the period was approved by the employee's supervisor, against the roster or attendance record, before payment.

**IF IT FAILS**

Have any timesheet approved by the person who processed it re-approved independently, and review that person's other timesheets for the period.

## C43 Claims approved by a manager

FINANCE LEAD · S50

**REPORTED TODAY**

Claims approved by a manager: reported in place only in some areas, cases or periods.

**TARGET OPERATING PRACTICE**

Each expense claim is approved before payment by a manager other than the claimant, against receipts and the expense policy.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve expense claims, within what limits, and confirm that no one approves their own.
2. Set the expense system so that the person who processes an expense claim cannot approve it.
3. Review a recent month of expense claims for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E42**

Claim approval record
Cycle: before each payment

**SUCCESS MEASURE · M43**

Every expense claim in the period was approved by someone other than the person who processed it, before payment.

**IF IT FAILS**

Have any expense claim approved by the person who processed it re-approved independently, and review that person's other expense claims for the period.

## C44 Broker invoices against attendance

OPERATIONS LEAD · S51

**REPORTED TODAY**

Broker invoices against attendance: reported as not in place.

**TARGET OPERATING PRACTICE**

Every labour broker invoice is checked against the organisation's own attendance records before payment, and differences are resolved with the broker.

**IMPLEMENTATION ACTIVITIES**

1. Set the reconciliation: what is compared, how often (before each payment), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

**RECORDS TO KEEP · E43**

Broker invoice reconciliation
Cycle: before each payment

**SUCCESS MEASURE · M44**

Every broker invoice reconciliation due in the period was completed and reviewed, and every difference was resolved before payment.

**IF IT FAILS**

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

## C48 Block leave required

HR AND PAYROLL LEAD · S52

**REPORTED TODAY**

Most people in sensitive roles take block leave, with someone else doing their work.

**TARGET OPERATING PRACTICE**

Everyone in a sensitive role takes a block of consecutive leave each year, with their work done by someone else, and exceptions are approved.

**IMPLEMENTATION ACTIVITIES**

1. Set the requirement in writing, including which people in sensitive roles it applies to and who may approve an exception.
2. Apply it each year, and record each case and each approved exception.
3. Report coverage and exceptions to the accountable executive at least once a year.

**RECORDS TO KEEP · E47**

Block leave record
Cycle: each year

**SUCCESS MEASURE · M48**

Every person in a sensitive role in scope took a block of leave in the year with their work done by someone else, or has an approved exception.

**IF IT FAILS**

Where the requirement is not met, record why, agree a corrective action with a date and report it to the accountable executive.

## C51 Refunds approved independently

COMMERCIAL AND CUSTOMER LEAD · S65

**REPORTED TODAY**

Approval is sought only for large refunds or when staff are unsure.
(answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Every refund and credit note is approved by someone other than the person who processes it.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve refunds and credit notes, within what limits, and confirm that no one approves their own.
2. Set the refund workflow so that the person who processes a refund or credit note cannot approve it.
3. Review a recent month of refunds and credit notes for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E50**

Refund approval record
Cycle: before each refund is paid

**SUCCESS MEASURE · M51**

Every refund or credit note in the period was approved by someone other than the person who processed it, before payment.

**IF IT FAILS**

Have any refund or credit note approved by the person who processed it re-approved independently, and review that person's other refunds and credit notes for the period.

## C58 Customer detail changes verified

COMMERCIAL AND CUSTOMER LEAD · S66

**REPORTED TODAY**

Most changes are verified with the customer, but sales staff can still make them.

**TARGET OPERATING PRACTICE**

Every change to a customer's refund account, delivery address or contact numbers is verified with the customer through details already on file, and is made by someone outside sales.

**IMPLEMENTATION ACTIVITIES**

1. Write the confirmation step into the procedure: contact with the customer through details already on file, never details supplied with the request.
2. Limit who can make the change in the customer master file, and log how each change was confirmed.
3. Check the changes to customer details made in the last six months against the log, and confirm any that were not verified.

**RECORDS TO KEEP · E57**

Customer change log
Cycle: whenever a change is requested

**SUCCESS MEASURE · M58**

Every change to customer details in the period was verified with the customer through details already on file before it took effect, and was made by someone outside sales.

**IF IT FAILS**

Suspend any change to customer details that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

## C61 Application documents verified

FINANCE LEAD · S67

**REPORTED TODAY**

Documents are checked only if something looks wrong.

**TARGET OPERATING PRACTICE**

The key information in every credit application is verified with its source, such as the employer, the bank or a verification service, before credit is approved.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for credit applications: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each credit application.
3. Look back over credit applications from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E60**

Credit application file
Cycle: before each approval

**SUCCESS MEASURE · M61**

Every credit application in the period has a credit application file showing the key information verified with its source before approval.

**IF IT FAILS**

Where a credit application went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C66 Fraud indicators screened

COMMERCIAL AND CUSTOMER LEAD · S68

**REPORTED TODAY**

Assessors rely on their own experience, without set indicators. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Every claim is screened against defined indicators, such as early claims, repeat claimants and recurring service providers, and flagged claims are referred for review.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in claims and the report, query or alert that finds them.
2. Name who reviews the output for every claim and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E65**

Claims screening log
Cycle: for every claim

**SUCCESS MEASURE · M66**

Every claim in the period was screened against the indicators, and every flagged claim was referred and has a recorded outcome.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C67 Everything supplied is billed

FINANCE LEAD · S69

**REPORTED TODAY**

Billing depends on staff remembering. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every delivery or service provided is matched to an invoice, and unbilled items are investigated.

**IMPLEMENTATION ACTIVITIES**

1. Set the reconciliation: what is compared, how often (weekly), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

**RECORDS TO KEEP · E66**

Delivery-to-invoice match report
Cycle: weekly

**SUCCESS MEASURE · M67**

Every delivery-to-invoice match report due in the period was completed and reviewed, and every difference was billed or investigated to a recorded conclusion.

**IF IT FAILS**

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

## C68 Customers warned about payment redirection

FINANCE LEAD · S70

**REPORTED TODAY**

The bank account appears on invoices, but there is no warning about changes.

**TARGET OPERATING PRACTICE**

Every invoice and statement shows the organisation's bank account and states that it will never be changed by email or message alone.

**IMPLEMENTATION ACTIVITIES**

1. Add the bank account and the warning to every invoice and statement template.
2. Withdraw any template, or manual invoice format, that does not carry them.
3. Check the templates each quarter and whenever the bank account changes.

**RECORDS TO KEEP · E67**

Template register
Cycle: each quarter

**SUCCESS MEASURE · M68**

At the end of the period, the template register shows the bank account and the warning on every invoice and statement template, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C69 Non-standard prices approved

COMMERCIAL AND CUSTOMER LEAD · S71

**REPORTED TODAY**

Non-standard prices approved: reported as not in place.

**TARGET OPERATING PRACTICE**

Prices or discounts outside the standard are approved by someone other than the salesperson, within set limits, before the sale is invoiced.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve non-standard prices and discounts, within what limits, and confirm that no one approves their own.
2. Set the sales system so that the person who processes a non-standard price or discount cannot approve it.
3. Review a recent month of non-standard prices and discounts for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E68**

Price approval record
Cycle: before each sale is invoiced

**SUCCESS MEASURE · M69**

Every non-standard price or discount in the period was approved by someone other than the person who processed it, within set limits before invoicing.

**IF IT FAILS**

Have any non-standard price or discount approved by the person who processed it re-approved independently, and review that person's other non-standard prices and discounts for the period.

## C70 Agent sales verified

COMMERCIAL AND CUSTOMER LEAD · S72

**REPORTED TODAY**

Agent sales verified: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Sales reported by agents or resellers are checked against real customer activity, such as payments received or goods delivered, before commission is paid.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for commission payments: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each commission payment.
3. Look back over commission payments from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E69**

Commission verification
Cycle: before each commission payment

**SUCCESS MEASURE · M70**

Every commission payment in the period has a commission verification showing the sales verified against customer activity before payment.

**IF IT FAILS**

Where a commission payment went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C71 Vouchers controlled in the system

COMMERCIAL AND CUSTOMER LEAD · S73

**REPORTED TODAY**

Vouchers controlled in the system: reported as set out or agreed but not yet working in practice. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Vouchers, gift cards and promotion codes are issued and redeemed only through a system that prevents duplicates and records who issued and redeemed each one.

**IMPLEMENTATION ACTIVITIES**

1. Issue and redeem every voucher, gift card and promotion code through one system that generates unique codes.
2. Restrict who can issue codes, and record each issue and redemption against the user.
3. Review the report monthly for duplicates, bulk issues and redemptions by staff.

**RECORDS TO KEEP · E70**

Voucher issue and redemption report
Cycle: monthly

**SUCCESS MEASURE · M71**

At the end of the period, the voucher issue and redemption report shows every voucher and code issued and redeemed through the system, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

### C72 **Human review before a customer is blocked**

FRAUD RISK LEAD · S74

**REPORTED TODAY**

Human review before a customer is blocked: reported in place only in some areas, cases or periods.

**TARGET OPERATING PRACTICE**

Before a customer is blocked or a claim declined because of a fraud flag, a trained person reviews the evidence and records the decision and its reason.

**IMPLEMENTATION ACTIVITIES**

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

**RECORDS TO KEEP · E71**

Flag review log
Cycle: each year

**SUCCESS MEASURE · M72**

In the period, every block or decline based on a fraud flag was reviewed by a person before it took effect.

**IF IT FAILS**

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

### C73 **Daily reconciliation**

OPERATIONS LEAD · S75

**REPORTED TODAY**

Takings are reconciled occasionally, or only when there is a shortage.

**TARGET OPERATING PRACTICE**

Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated.

**IMPLEMENTATION ACTIVITIES**

1. Set the reconciliation: what is compared, how often (daily), who prepares it and who reviews it.
2. Keep a log of differences with the explanation and outcome of each, and a threshold above which a difference is escalated.
3. Review the first month of reconciliations and differences, and correct the procedure where differences were left open.

**RECORDS TO KEEP · E72**

Daily cash reconciliation
Cycle: daily

**SUCCESS MEASURE · M73**

Every daily cash reconciliation due in the period was completed and reviewed, and every difference has a recorded explanation.

**IF IT FAILS**

Investigate any difference left unexplained, and escalate repeated differences at the same point or involving the same person.

### C75 **Independent blind counts**

FINANCE LEAD · S76

**REPORTED TODAY**

The stores team counts, and someone else glances at the results.

**TARGET OPERATING PRACTICE**

Every count is carried out or observed by people independent of the stores team, counting without sight of recorded quantities.

**IMPLEMENTATION ACTIVITIES**

1. Set the plan: which counts are covered, how often, who carries out the check and who observes it.
2. Prepare check sheets that do not show the recorded position, and compare the results with the record only after the check.
3. Investigate the differences from the first check before any record is adjusted.

**RECORDS TO KEEP · E74**

Count sheets
Cycle: at each count

**SUCCESS MEASURE · M75**

Every check planned for the period was carried out by, or under the observation of, people independent of the stores team, without sight of recorded quantities, and every difference was explained before a record was adjusted.

**IF IT FAILS**

Recheck and investigate any unexplained difference, and review access to the items concerned.

### C80 **Devices wiped before disposal**

IT LEAD · S78

**REPORTED TODAY**

Devices wiped before disposal: reported in place only in some areas, cases or periods.

**TARGET OPERATING PRACTICE**

Every laptop, phone and other device is wiped of the organisation's data, and the wipe recorded, before it is disposed of, sold, reissued or returned.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for devices leaving use: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each device leaving use.
3. Look back over devices leaving use from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E79**

Device disposal record
Cycle: before each device leaves use

**SUCCESS MEASURE · M80**

Every device leaving use in the period has a device disposal record showing a recorded wipe before disposal, sale, reissue or return.

**IF IT FAILS**

Where a device leaving use went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C81 **Paid before collection**

FINANCE LEAD · S79

**REPORTED TODAY**

Payment is confirmed in the bank for larger sales only. (answered by Finance)

**TARGET OPERATING PRACTICE**

Payment is confirmed on the organisation's own bank statement before any goods are collected.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for collections of goods: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each collection of goods.
3. Look back over collections of goods from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E80**

Release record
Cycle: before each release

**SUCCESS MEASURE · M81**

Every collection of goods in the period has a release record showing payment confirmed on the bank statement before release.

**IF IT FAILS**

Where a collection of goods went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C82 **Changed collection instructions verified**

OPERATIONS LEAD · S80

**REPORTED TODAY**

Changed collection instructions verified: reported in place only in some areas, cases or periods.

**TARGET OPERATING PRACTICE**

When an instruction to release or collect goods changes, such as a new delivery address or a different collector, the change is verified through known contact details, and the collector's identity is checked at release.

**IMPLEMENTATION ACTIVITIES**

1. Write the confirmation step into the procedure: contact with the customer through details already on file, with an identity check at release, never details supplied with the request.
2. Limit who can make the change, and log how each change was confirmed.
3. Check the changed collection instructions made in the last six months against the log, and confirm any that were not verified.

**RECORDS TO KEEP · E81**

Release log
Cycle: whenever an instruction changes

**SUCCESS MEASURE · M82**

Every changed collection instruction in the period was verified through known contact details before release, and every collector's identity was checked at release.

**IF IT FAILS**

Suspend any changed collection instruction that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

## C83 **Fuel matched to distance**

OPERATIONS LEAD · S81

**REPORTED TODAY**

Fuel purchases are not compared with vehicle use.

**TARGET OPERATING PRACTICE**

Every vehicle's fuel purchases are compared with tracking data, distance travelled and expected consumption, and exceptions are investigated.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in fuel purchases and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E82**

Fuel exception report
Cycle: monthly

**SUCCESS MEASURE · M83**

The review of fuel purchases ran monthly throughout the period, and every exception it raised was investigated and has a recorded outcome.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C84 **Dispatch matched to orders**

OPERATIONS LEAD · S82

**REPORTED TODAY**

Dispatch matched to orders: reported as not in place.

**TARGET OPERATING PRACTICE**

Every dispatch is matched to an approved customer order before the goods leave.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for dispatches: what is checked, by whom, and who may approve an exception.
2. Set the dispatch system so that no dispatch proceeds until the check is recorded as passed.
3. Look back over dispatches from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E83**

Dispatch record
Cycle: before each dispatch

**SUCCESS MEASURE · M84**

Every dispatch in the period has a dispatch record showing a match to an approved order before the goods left.

**IF IT FAILS**

Where a dispatch went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C85 **Organised theft assessed**

OPERATIONS LEAD · S83

**REPORTED TODAY**

Organised theft assessed: reported as not in place.

**TARGET OPERATING PRACTICE**

The risk of organised theft, such as theft of copper, cable, metals or fuel, is assessed each year with the security provider, and the agreed measures are put in place.

**IMPLEMENTATION ACTIVITIES**

1. Assess each site with the security provider, starting with sites holding copper, cable, metals or fuel.
2. Agree the measures for each site and who puts them in place.
3. Review the assessment each year and after any incident.

**RECORDS TO KEEP · E84**

Organised theft assessment
Cycle: each year

**SUCCESS MEASURE · M85**

The assessment current at the end of the period shows every site holding copper, cable, metals or fuel assessed with the security provider, with the agreed measures in place.

**IF IT FAILS**

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

## C86 **Losses tracked and reported**

FINANCE LEAD · S84

**REPORTED TODAY**

Losses tracked and reported: reported as set out or agreed but not yet working in practice.

**TARGET OPERATING PRACTICE**

Losses of cash, stock and assets are tracked over time and by location, and reported to management each month with the actions taken.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in losses of cash, stock and assets and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E85**

Loss report
Cycle: monthly

**SUCCESS MEASURE · M86**

The review of losses of cash, stock and assets ran monthly throughout the period, and every exception it raised was reported to management with the action taken.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C87 **Multi-factor on all email**

IT LEAD · S85

**REPORTED TODAY**

Email accounts are protected by passwords only.

**TARGET OPERATING PRACTICE**

Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

**IMPLEMENTATION ACTIVITIES**

1. List every email account in scope and how it is set today.
2. Apply the setting to each, starting with executives' and finance mailboxes, and record any approved exception.
3. Produce the email security report monthly, and follow up any gap.

**RECORDS TO KEEP · E86**

Email security report
Cycle: monthly

**SUCCESS MEASURE · M87**

At the end of the period, the email security report shows multi-factor authentication on every email account, including executives' and shared mailboxes, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C88 **Email never enough on its own**

CHIEF FINANCIAL OFFICER · S86

**REPORTED TODAY**

Payment changes received by email are acted on as received.
(answered by IT and information)

**TARGET OPERATING PRACTICE**

An organisation-wide rule requires confirmation through a separate, known channel for every payment, salary or urgent request received by email, and staff follow it.

**IMPLEMENTATION ACTIVITIES**

1. Write the rule and have it approved by the chief executive.
2. Brief staff who act on payment or salary requests, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

**RECORDS TO KEEP · E87**

Verification rule record
Cycle: each year

**SUCCESS MEASURE · M88**

All staff who act on payment or salary requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested.

**IF IT FAILS**

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

## C89 Verification for calls, voice notes and video

CHIEF FINANCIAL OFFICER · S87

**REPORTED TODAY**

Some staff check unusual requests, depending on their own judgement.

**TARGET OPERATING PRACTICE**

An agreed method, such as a call-back on a known number or a code word, verifies any request made by phone, voice note or video; it applies to everyone, including executives, and staff know they are expected to use it.

**IMPLEMENTATION ACTIVITIES**

1. Write the rule and have it approved by the chief executive.
2. Brief staff who act on requests by phone, voice note or video, including executives and their assistants, and record who has been briefed.
3. Test the rule at least once a year, for example with a simulated request, and act on the result.

**RECORDS TO KEEP · E88**

Verification method record
Cycle: each year

**SUCCESS MEASURE · M89**

All staff who act on requests by phone, voice note or video were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including requests that appeared to come from executives.

**IF IT FAILS**

Where the rule was not followed, establish why, brief the people concerned again and check whether any payment or disclosure resulted.

## C92 Customer logins protected

IT LEAD · S88

**REPORTED TODAY**

Multi-factor authentication is offered, but customers can opt out.

**TARGET OPERATING PRACTICE**

Customer logins are protected with multi-factor authentication, device recognition and limits on repeated failed attempts.

**IMPLEMENTATION ACTIVITIES**

1. List every customer login route in scope and how it is set today.
2. Apply the setting to each, starting with routes that can change payment details or redeem value, and record any approved exception.
3. Produce the customer authentication report monthly, and follow up any gap.

**RECORDS TO KEEP · E91**

Customer authentication report
Cycle: monthly

**SUCCESS MEASURE · M92**

At the end of the period, the customer authentication report shows multi-factor authentication, device recognition and attempt limits on every customer login route, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C93 Compromises reported as POPIA requires

IT LEAD · S89

**REPORTED TODAY**

A compromise would be handled as it happens, without a set process. (answered by IT and information)

**TARGET OPERATING PRACTICE**

A procedure sets out who decides, who notifies the Information Regulator through its eServices portal and the people affected, and how quickly, as section 22 of POPIA requires.

**IMPLEMENTATION ACTIVITIES**

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

**RECORDS TO KEEP · E92**

Breach response procedure
Cycle: each year

**SUCCESS MEASURE · M93**

In the period, the procedure was tested or used, and every compromise discovered was notified as soon as reasonably possible, with any delay justified and recorded.

**IF IT FAILS**

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

## C95 Help desk resets verified

IT LEAD · S90

**REPORTED TODAY**

Most resets need verification through a trusted route, such as the person's manager or a number on file. (answered by IT and information)

**TARGET OPERATING PRACTICE**

Every password or multi-factor reset is verified through a route the caller does not control, such as a call-back to a number on file or a manager's confirmation through a known channel.

**IMPLEMENTATION ACTIVITIES**

1. Write the confirmation step into the procedure: a call-back to a number on file, or a manager's confirmation through a known channel, never details supplied with the request.
2. Limit who can make the change in the help desk system, and log how each change was confirmed.
3. Check the password and multi-factor resets made in the last six months against the log, and confirm any that were not verified.

**RECORDS TO KEEP · E94**

Reset log
Cycle: whenever a reset is requested

**SUCCESS MEASURE · M95**

Every password or multi-factor reset made in the period was confirmed through a route the caller did not control before it took effect, or is a recorded and approved exception.

**IF IT FAILS**

Suspend any password or multi-factor reset that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

## C96 Multi-factor on critical systems

IT LEAD · S91

**REPORTED TODAY**

These systems are protected by passwords only. (answered by IT and information)

**TARGET OPERATING PRACTICE**

Multi-factor authentication is required for remote access, cloud systems, the banking platform and every system that can move money or change master data.

**IMPLEMENTATION ACTIVITIES**

1. List every system or access route in scope and how it is set today.
2. Apply the setting to each, starting with the banking platform and remote access, and record any approved exception.
3. Produce the multi-factor coverage report monthly, and follow up any gap.

**RECORDS TO KEEP · E95**

Multi-factor coverage report
Cycle: monthly

**SUCCESS MEASURE · M96**

At the end of the period, the multi-factor coverage report shows multi-factor authentication on remote access, cloud systems, the banking platform and every system that can move money or change master data, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C97 Access to personal information limited

LEGAL AND COMPLIANCE LEAD · S92

**REPORTED TODAY**

Access is limited for some systems only. (answered by IT and information)

**TARGET OPERATING PRACTICE**

In every system, access to personal information is limited to people who need it for their work, and bulk exports are restricted and logged.

**IMPLEMENTATION ACTIVITIES**

1. List every system holding personal information in scope and how it is set today.
2. Apply the setting to each, starting with customer and employee systems, and record any approved exception.
3. Produce the access review each quarter, and follow up any gap.

**RECORDS TO KEEP · E96**

Access review
Cycle: each quarter

**SUCCESS MEASURE · M97**

At the end of the period, the access review shows access limited by role, and exports restricted and logged, in every system holding personal information, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C98 Approval numbers protected

IT LEAD · S93

**REPORTED TODAY**

Staff have been told about SIM swaps, but nothing has been changed. (answered by IT and information)

**TARGET OPERATING PRACTICE**

Every number used to approve payments or reset access has a network SIM-swap lock, or has been replaced by an authenticator app.

**IMPLEMENTATION ACTIVITIES**

1. List every approval number in scope and how it is set today.
2. Apply the setting to each, starting with numbers that approve payments, and record any approved exception.
3. Produce the approval numbers register each quarter, and follow up any gap.

**RECORDS TO KEEP · E97**

Approval numbers register
Cycle: each quarter

**SUCCESS MEASURE · M98**

At the end of the period, the approval numbers register shows a SIM-swap lock or an authenticator app for every number used for approvals, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C99 Assistant permissions limited

IT LEAD · S94

**REPORTED TODAY**

Assistant permissions limited: reported in place only in some areas, cases or periods. (answered by IT and information)

**TARGET OPERATING PRACTICE**

AI assistants have only the permissions each task needs, and cannot make payments, change records or send messages without a person's approval.

**IMPLEMENTATION ACTIVITIES**

1. List every AI assistant in scope and how it is set today.
2. Apply the setting to each, starting with assistants connected to finance systems or email, and record any approved exception.
3. Produce the AI assistant permissions register each quarter, and follow up any gap.

**RECORDS TO KEEP · E98**

AI assistant permissions register
Cycle: each quarter

**SUCCESS MEASURE · M99**

At the end of the period, the AI assistant permissions register shows no assistant able to pay, change records or send messages without a person's approval, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C100 Staff guided on what not to share

COMMERCIAL AND CUSTOMER LEAD · S95

**REPORTED TODAY**

Staff guided on what not to share: reported as not in place. (answered by IT and information)

**TARGET OPERATING PRACTICE**

Staff are guided on what not to share about their work online, such as who approves payments or when executives are travelling, at induction and each year.

**IMPLEMENTATION ACTIVITIES**

1. Set the content and who must complete it, using current schemes relevant to their work.
2. Track completion each year, and follow up anyone who has not completed it.
3. Refresh the content each year, and test understanding where the risk is highest.

**RECORDS TO KEEP · E99**

Guidance record
Cycle: each year

**SUCCESS MEASURE · M100**

Every employee completed the training at induction and within the year, and completion is recorded.

**IF IT FAILS**

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

## C101 Compromise playbook

IT LEAD · S96

**REPORTED TODAY**

There is no plan; each case would be handled from scratch. (answered by IT and information)

**TARGET OPERATING PRACTICE**

A written plan for an email compromise or account takeover covers locking accounts, revoking sessions, informing the bank and warning suppliers and customers, and people know their roles.

**IMPLEMENTATION ACTIVITIES**

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

**RECORDS TO KEEP · E100**

Compromise response plan
Cycle: each year

**SUCCESS MEASURE · M101**

In the period, the plan was tested or used, and the actions arising are complete or on schedule.

**IF IT FAILS**

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

## C102 Brand impersonation monitored and removed

CHIEF FINANCIAL OFFICER · S97

**REPORTED TODAY**

Brand impersonation monitored and removed: reported as not in place. (answered by IT and information)

**TARGET OPERATING PRACTICE**

The organisation watches for fake websites, social media accounts and adverts that impersonate it, and has each one taken down.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in websites, social media and adverts and the report, query or alert that finds them.
2. Name who reviews the output weekly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E101**

Impersonation log
Cycle: weekly

**SUCCESS MEASURE · M102**

The review of websites, social media and adverts ran weekly throughout the period, and every exception it raised was reported for takedown, with its removal recorded.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C103 Domain protected against spoofing

IT LEAD · S98

**REPORTED TODAY**

Domain protected against spoofing: partly in place. (answered by IT and information)

**TARGET OPERATING PRACTICE**

The organisation's email domains are protected against spoofing with SPF, DKIM and a DMARC policy set to quarantine or reject.

**IMPLEMENTATION ACTIVITIES**

1. List every email domain in scope and how it is set today.
2. Apply the setting to each, starting with the main sending domain, and record any approved exception.
3. Produce the domain protection report each quarter, and follow up any gap.

**RECORDS TO KEEP · E102**

Domain protection report
Cycle: each quarter

**SUCCESS MEASURE · M103**

At the end of the period, the domain protection report shows SPF, DKIM and a DMARC policy of quarantine or reject on every domain, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C01 Training on joining

HR AND PAYROLL LEAD · S25

**REPORTED TODAY**

Training on joining: reported in place only in some areas, cases or periods. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Every new employee completes fraud and ethics training in their first month, covering the code of conduct, how to report concerns and the schemes relevant to their role.

**IMPLEMENTATION ACTIVITIES**

1. Set the content and who must complete it, using current schemes relevant to their work.
2. Track completion monthly, and follow up anyone who has not completed it.
3. Refresh the content each year, and test understanding where the risk is highest.

**RECORDS TO KEEP · E01**

Training completion record
Cycle: monthly

**SUCCESS MEASURE · M01**

Every new employee completed the training within their first month, and completion is recorded.

**IF IT FAILS**

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

## C04 Directors identified

PROCUREMENT LEAD · S29

**REPORTED TODAY**

Owners are identified only when something raises a concern. (answered by Procurement)

**TARGET OPERATING PRACTICE**

The directors and owners of every new supplier, including those behind holding companies, are identified from an independent source such as CIPC.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for new suppliers: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each new supplier.
3. Look back over new suppliers from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E04**

Supplier set-up file
Cycle: before each new supplier is first paid

**SUCCESS MEASURE · M04**

Every new supplier in the period has a supplier set-up file showing directors and owners identified from an independent source before the first payment.

**IF IT FAILS**

Where a new supplier went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C05 Directors compared with staff

PROCUREMENT LEAD · S29

**REPORTED TODAY**

Directors compared with staff: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Supplier directors, owners, addresses and bank accounts are compared with employee records when a supplier is set up and at least once a year, and every match is investigated.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in supplier and employee records and the report, query or alert that finds them.
2. Name who reviews the output at set-up and at least once a year and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E05**

Supplier and employee match report
Cycle: at set-up and at least once a year

**SUCCESS MEASURE · M05**

Every new supplier was compared with employee records at set-up, the whole supplier file was compared at least once in the year, and every match has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C06 Suppliers re-checked

PROCUREMENT LEAD · S29

**REPORTED TODAY**

Suppliers re-checked: reported as set out or agreed but not yet working in practice. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Existing suppliers are re-checked against the set-up checks at least every two years, and the highest-value suppliers each year.

**IMPLEMENTATION ACTIVITIES**

1. Set the re-check cycle by supplier value and risk.
2. Repeat the set-up checks for each supplier due, starting with the highest-value suppliers.
3. Record each result, and verify any change found before the next payment.

**RECORDS TO KEEP · E06**

Supplier re-check log
Cycle: each year

**SUCCESS MEASURE · M06**

Every supplier due for a re-check in the period was re-checked, and every change found was verified before the next payment.

**IF IT FAILS**

Where a re-check finds a change that was not verified, hold payments to that supplier until it is verified.

## C07 Dormant suppliers deactivated

PROCUREMENT LEAD · S29

**REPORTED TODAY**

Dormant suppliers deactivated: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Suppliers not used for a set period, such as twelve months, are deactivated, and reactivating one requires the full set-up checks.

**IMPLEMENTATION ACTIVITIES**

1. Set the period after which an unused supplier is deactivated.
2. Run the dormant supplier report each quarter, and deactivate the suppliers it lists.
3. Require the full set-up checks before any supplier is reactivated.

**RECORDS TO KEEP · E07**

Dormant supplier report
Cycle: each quarter

**SUCCESS MEASURE · M07**

The dormant supplier report was run each quarter in the period, and every supplier unused for the set period is deactivated.

**IF IT FAILS**

Bring the dormant supplier report up to date, and check whether anything was missed while it was out of date.

## C12 Approved order before commitment

PROCUREMENT LEAD · S33

**REPORTED TODAY**

Most purchases are approved before commitment, through a purchase order or another record. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Every purchase is approved by someone with the authority to do so before the organisation commits to it, and the approval is recorded.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for purchases: what is checked, by whom, and who may approve an exception.
2. Set the purchasing system so that no purchase proceeds until the check is recorded as passed.
3. Look back over purchases from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E12**

Purchase order or approval record
Cycle: before each commitment

**SUCCESS MEASURE · M12**

Every purchase in the period has a purchase order or approval record showing approval by an authorised person dated before the commitment.

**IF IT FAILS**

Where a purchase went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C13 Receipt recorded before payment

OPERATIONS LEAD · S33

**REPORTED TODAY**

Receipt is recorded for most deliveries, but not always before payment. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Receipt of goods is always recorded before the related invoice is paid.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for goods invoices: what is checked, by whom, and who may approve an exception.
2. Set the receiving system so that no goods invoice proceeds until the check is recorded as passed.
3. Look back over goods invoices from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E13**

Goods received note
Cycle: before each payment

**SUCCESS MEASURE · M13**

Every goods invoice in the period has a goods received note showing receipt recorded before the invoice was paid.

**IF IT FAILS**

Where a goods invoice went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C14 Quantities checked

OPERATIONS LEAD · S33

**REPORTED TODAY**

Quantities checked: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Delivered quantities are checked against the delivery note and the order when goods arrive, and differences are recorded before the delivery is accepted.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for deliveries: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each delivery.
3. Look back over deliveries from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E14**

Goods received note
Cycle: at each delivery

**SUCCESS MEASURE · M14**

Every delivery in the period has a goods received note showing quantities checked against the order and delivery note, with any difference recorded.

**IF IT FAILS**

Where a delivery went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C15 **Services confirmed**

OPERATIONS LEAD · S33

**REPORTED TODAY**

Services confirmed: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

For every service, the person who received it confirms in writing that it was delivered as ordered before the invoice is paid.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for service invoices: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each service invoice.
3. Look back over service invoices from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E15**

Service delivery confirmation
Cycle: before each payment

**SUCCESS MEASURE · M15**

Every service invoice in the period has a service delivery confirmation showing written confirmation of delivery from the person who received the service before payment.

**IF IT FAILS**

Where a service invoice went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C19 **Quote and tender thresholds**

PROCUREMENT LEAD · S36

**REPORTED TODAY**

Quote and tender thresholds: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Amounts approved by management set when two or more quotes or a formal tender are required, and a purchase above them without competition needs a recorded, approved reason.

**IMPLEMENTATION ACTIVITIES**

1. Set the thresholds for quotes and tenders, and who may approve an exception.
2. Add the threshold check to the purchasing procedure and system.
3. Review purchases above the thresholds in the last twelve months for quotes or approved exceptions.

**RECORDS TO KEEP · E19**

Procurement file
Cycle: before each commitment

**SUCCESS MEASURE · M19**

Every purchase above the quote threshold in the period has a procurement file showing the required quotes or tender, or an approved reason for not obtaining them.

**IF IT FAILS**

Where a purchase above the quote threshold went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C24 **Data reviewed for unusual patterns**

INTERNAL AUDIT · S40

**REPORTED TODAY**

Data reviewed for unusual patterns: reported as not in place. (answered by Risk and investigations)

**TARGET OPERATING PRACTICE**

Procurement and supplier payment data is reviewed monthly, by someone independent of buying and paying, for patterns such as split orders, duplicate invoices, new suppliers paid quickly and payments just below approval limits.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in procurement and supplier payment data and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E24**

Monthly exception review
Cycle: monthly

**SUCCESS MEASURE · M24**

The review of procurement and supplier payment data ran monthly throughout the period, and every exception it raised has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C25 **Independent review of procurement**

INTERNAL AUDIT · S40

**REPORTED TODAY**

Independent review of procurement: partly in place. (answered by Risk and investigations)

**TARGET OPERATING PRACTICE**

Internal audit or an external reviewer examines procurement at least every two years, including supplier set-up, competition and payment, and management acts on the findings.

**IMPLEMENTATION ACTIVITIES**

1. Include procurement in the internal audit plan or appoint an external reviewer, with a scope that covers the fraud schemes concerned.
2. Agree with the reviewer what will be tested and how findings will be reported.
3. Track each finding to closure, and report progress to the oversight body.

**RECORDS TO KEEP · E25**

Review report
Cycle: within the last two years

**SUCCESS MEASURE · M25**

A review of procurement was completed within the last two years, and its findings are closed or on schedule.

**IF IT FAILS**

Where findings are overdue, escalate them to the oversight body with the reason and a new date.

## C26 **Split orders monitored**

PROCUREMENT LEAD · S40

**REPORTED TODAY**

Split orders monitored: reported as set out or agreed but not yet working in practice. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Orders to the same supplier are reviewed monthly for several smaller orders that together exceed an approval limit, and each instance is followed up.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in orders to the same supplier and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E26**

Split order report
Cycle: monthly

**SUCCESS MEASURE · M26**

The review of orders to the same supplier ran monthly throughout the period, and every exception it raised has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C28 **Contract register**

PROCUREMENT LEAD · S41

**REPORTED TODAY**

Contract register: reported as not in place. (answered by Procurement)

**TARGET OPERATING PRACTICE**

A register lists every active supplier contract with its value, term, owner and renewal date, and is kept current.

**IMPLEMENTATION ACTIVITIES**

1. Create the contract register with the fields it needs, and name who maintains it.
2. Populate it from current information, and resolve gaps with the people responsible.
3. Review it each quarter and whenever a contract is signed, varied or ends.

**RECORDS TO KEEP · E28**

Contract register
Cycle: each quarter

**SUCCESS MEASURE · M28**

The contract register was reviewed as planned in the period, and every active contract is recorded with its owner and dates.

**IF IT FAILS**

Bring the contract register up to date, and check whether anything was missed while it was out of date.

## C30 **Large variations escalated**

PROCUREMENT LEAD · S41

**REPORTED TODAY**

Large variations escalated: reported as set out or agreed but not yet working in practice. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Variations above a set percentage of the original value are approved at a higher level than the original award.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve large variations, within what limits, and confirm that no one approves their own.
2. Record the approver on each large variation, and check that it is never the person who processed it.
3. Review a recent month of large variations for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E30**

Variation approval record
Cycle: before each large variation proceeds

**SUCCESS MEASURE · M30**

Every large variation in the period was approved by someone other than the person who processed it, at the higher level before the work went ahead.

**IF IT FAILS**

Have any large variation approved by the person who processed it re-approved independently, and review that person's other large variations for the period.

## C31 **Written supplier contracts**

PROCUREMENT LEAD · S41

**REPORTED TODAY**

Written supplier contracts: reported in place only in some areas, cases or periods. (answered by Procurement)

**TARGET OPERATING PRACTICE**

Ongoing or significant supplier relationships are governed by signed written contracts that set out price, scope, terms and audit rights.

**IMPLEMENTATION ACTIVITIES**

1. Set the value or duration above which a signed contract is required.
2. Identify suppliers above it without a signed contract, and put contracts in place.
3. Check the contract register each quarter for new suppliers above the threshold.

**RECORDS TO KEEP · E31**

Contract register
Cycle: each quarter

**SUCCESS MEASURE · M31**

The contract register was reviewed as planned in the period, and every ongoing or significant supplier has a signed contract.

**IF IT FAILS**

Bring the contract register up to date, and check whether anything was missed while it was out of date.

## C34 Headcount verification done

HR AND PAYROLL LEAD · S43

**REPORTED TODAY**

Headcount verification done: not in place. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

At least every two years, the people on payroll are matched to real employees through a headcount or verification exercise run independently of payroll.

**IMPLEMENTATION ACTIVITIES**

1. Plan the exercise with HR and internal audit, covering every person paid.
2. Confirm each person's identity and role in person or through their manager, independently of payroll.
3. Investigate every person who cannot be matched, and stop pay where needed.

**RECORDS TO KEEP · E34**

Headcount verification report
Cycle: every two years

**SUCCESS MEASURE · M34**

Every check planned for the period was carried out independently of payroll and covering everyone paid, and every difference was explained before a record was adjusted.

**IF IT FAILS**

Recheck and investigate any unexplained difference, and review access to the items concerned.

## C35 Independent review of payroll

HR AND PAYROLL LEAD · S43

**REPORTED TODAY**

Independent review of payroll: partly in place. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Internal audit or an external reviewer examines payroll at least every two years, including starters, leavers, changes and payments, and management acts on the findings.

**IMPLEMENTATION ACTIVITIES**

1. Include payroll in the internal audit plan or appoint an external reviewer, with a scope that covers the fraud schemes concerned.
2. Agree with the reviewer what will be tested and how findings will be reported.
3. Track each finding to closure, and report progress to the oversight body.

**RECORDS TO KEEP · E25**

Review report
Cycle: within the last two years

**SUCCESS MEASURE · M35**

A review of payroll was completed within the last two years, and its findings are closed or on schedule.

**IF IT FAILS**

Where findings are overdue, escalate them to the oversight body with the reason and a new date.

## C38 Qualifications verified

HR AND PAYROLL LEAD · S45

**REPORTED TODAY**

Certificates are accepted as presented. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Every qualification relied on for an appointment is verified with the issuing institution or through SAQA before the offer is final.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for appointments that rely on a qualification: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each appointment that relies on a qualification.
3. Look back over appointments that rely on a qualification from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E37**

Qualification verification result
Cycle: before each offer is final

**SUCCESS MEASURE · M38**

Every appointment that relies on a qualification in the period has a qualification verification result showing the qualification verified before the offer was final.

**IF IT FAILS**

Where an appointment that relies on a qualification went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C45 High-risk roles identified

HR AND PAYROLL LEAD · S52

**REPORTED TODAY**

Managers know informally which roles are risky. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

A maintained list of high-risk roles covers the whole organisation, including roles that can move money, change master data or manage system access.

**IMPLEMENTATION ACTIVITIES**

1. Create the list of high-risk roles with the fields it needs, and name who maintains it.
2. Populate it from current information, and resolve gaps with the people responsible.
3. Review it each year and whenever roles or system access change.

**RECORDS TO KEEP · E44**

List of high-risk roles
Cycle: each year

**SUCCESS MEASURE · M45**

The list of high-risk roles was reviewed as planned in the period, and every role that can move money, change master data or manage system access is on it.

**IF IT FAILS**

Bring the list of high-risk roles up to date, and check whether anything was missed while it was out of date.

## C46 No conflicting duties when covering

HR AND PAYROLL LEAD · S52

**REPORTED TODAY**

No conflicting duties when covering: reported as set out or agreed but not yet working in practice. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

People in high-risk roles never hold conflicting duties, including temporarily when covering for colleagues; cover arrangements are approved and checked against the list of conflicting duties.

**IMPLEMENTATION ACTIVITIES**

1. List who holds the duties concerned, and remove any combination that lets one person hold conflicting duties, including while covering for a colleague.
2. Set system access settings so that the combination cannot be granted again without recorded approval.
3. Review the combinations at least once a year and whenever roles change, including temporary cover.

**RECORDS TO KEEP · E45**

Cover arrangement log
Cycle: whenever cover is arranged

**SUCCESS MEASURE · M46**

The review for the period found no one able to hold conflicting duties, including while covering for a colleague, and every cover arrangement was checked and approved.

**IF IT FAILS**

Remove the combination, review the cover arrangements handled while it existed, and record the outcome.

## C47 No single point of knowledge

HR AND PAYROLL LEAD · S52

**REPORTED TODAY**

No single point of knowledge: reported as set out or agreed but not yet working in practice. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Every critical process in a high-risk role can be performed by at least two trained people, so that no one person is the only one who understands or controls it.

**IMPLEMENTATION ACTIVITIES**

1. List the critical processes in high-risk roles and who can perform each.
2. Train a second person for each process that only one person can perform.
3. Review the list each year and whenever people leave or change roles.

**RECORDS TO KEEP · E46**

Cover and skills matrix
Cycle: each year

**SUCCESS MEASURE · M47**

Every critical process in scope has at least two trained people, or has an approved exception.

**IF IT FAILS**

Where the requirement is not met, record why, agree a corrective action with a date and report it to the accountable executive.

## C49 Concerns raised fairly

HR AND PAYROLL LEAD · S52

**REPORTED TODAY**

Concerns raised fairly: reported as not in place. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Managers have a defined, confidential route to raise and escalate concerns about an employee's behaviour, without making accusations, and each concern is assessed and recorded.

**IMPLEMENTATION ACTIVITIES**

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

**RECORDS TO KEEP · E48**

Concerns log
Cycle: each year

**SUCCESS MEASURE · M49**

In the period, every concern raised was assessed and its outcome recorded.

**IF IT FAILS**

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

## C50 Support for financial pressure

HR AND PAYROLL LEAD · S52

**REPORTED TODAY**

Support for financial pressure: reported as not in place. (answered by HR and payroll)

**TARGET OPERATING PRACTICE**

Employees in financial difficulty can use confidential support, such as financial wellness or an employee assistance programme, and staff know how to reach it.

**IMPLEMENTATION ACTIVITIES**

1. Choose the support offered, internally or through a provider.
2. Tell every employee how to reach it confidentially, at induction and each year.
3. Review its use each year, in aggregate only, and adjust the support.

**RECORDS TO KEEP · E49**

Support programme record
Cycle: each year

**SUCCESS MEASURE · M50**

Every employee was told how to reach the support during the year, and the support was available throughout the period.

**IF IT FAILS**

Where the requirement is not met, record why, agree a corrective action with a date and report it to the accountable executive.

## C52 **Returns received before credit**

COMMERCIAL AND CUSTOMER LEAD · S65

**REPORTED TODAY**

Returns received before credit: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Every return is matched to the goods physically coming back into stock before a credit is issued.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for credits for returned goods: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each credit for returned goods.
3. Look back over credits for returned goods from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E51**

Returns record
Cycle: before each credit is issued

**SUCCESS MEASURE · M52**

Every credit for returned goods in the period has a returns record showing the goods received back into stock before the credit was issued.

**IF IT FAILS**

Where a credit for returned goods went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C53 **Refund patterns reviewed**

COMMERCIAL AND CUSTOMER LEAD · S65

**REPORTED TODAY**

Refund patterns reviewed: reported in place only in some areas, cases or periods. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Refunds and credit notes are reviewed monthly for patterns, such as the same employee or customer, or amounts just below approval limits, and each pattern is followed up.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in refunds and credit notes and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E52**

Refund pattern review
Cycle: monthly

**SUCCESS MEASURE · M53**

The review of refunds and credit notes ran monthly throughout the period, and every exception it raised has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C54 **Post-period reversals reviewed**

COMMERCIAL AND CUSTOMER LEAD · S65

**REPORTED TODAY**

Post-period reversals reviewed: reported in place only in some areas, cases or periods. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Credit notes and reversals raised after each period end are reviewed by finance, so that sales reversed once targets were met are identified and investigated.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in post-period credit notes and reversals and the report, query or alert that finds them.
2. Name who reviews the output after each period end and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E53**

Post-period reversal review
Cycle: after each period end

**SUCCESS MEASURE · M54**

The reversals raised after each period end in the year were reviewed, and every one linked to period-end sales has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C55 **Claim evidence checked for AI**

COMMERCIAL AND CUSTOMER LEAD · S65

**REPORTED TODAY**

Claim evidence checked for AI: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Photographs and documents supporting refund or return requests are checked for manipulation, including AI-generated images, before the refund is approved, using checks proportionate to the value.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for refunds supported by images or documents: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each refund supported by images or documents.
3. Look back over refunds supported by images or documents from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E54**

Refund evidence check
Cycle: before each approval

**SUCCESS MEASURE · M55**

Every refund supported by images or documents in the period has a refund evidence check showing the supporting images or documents checked for manipulation before approval.

**IF IT FAILS**

Where a refund supported by images or documents went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C56 **Defined onboarding**

COMMERCIAL AND CUSTOMER LEAD · S66

**REPORTED TODAY**

Defined onboarding: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Every new customer goes through a defined onboarding process, with set identity and account checks, before goods, services or credit are provided.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for new customers: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each new customer.
3. Look back over new customers from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E55**

Customer onboarding file
Cycle: before each account is opened

**SUCCESS MEASURE · M56**

Every new customer in the period has a customer onboarding file showing the onboarding checks completed before goods, services or credit were provided.

**IF IT FAILS**

Where a new customer went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C57 **Business customers verified**

COMMERCIAL AND CUSTOMER LEAD · S66

**REPORTED TODAY**

Business customers verified: reported in place only in some areas, cases or periods. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Every business customer is confirmed as real and registered, for example through CIPC, and the people who may act for it are confirmed, before an account is opened.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for business customers: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each business customer.
3. Look back over business customers from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E56**

Customer onboarding file
Cycle: before each account is opened

**SUCCESS MEASURE · M57**

Every business customer in the period has a customer onboarding file showing registration and authorised representatives confirmed before the account was opened.

**IF IT FAILS**

Where a business customer went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C59 **Shared details flagged**

COMMERCIAL AND CUSTOMER LEAD · S66

**REPORTED TODAY**

Shared details flagged: reported as not in place. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

The system or a monthly review flags customers who share ID numbers, phone numbers, addresses or bank accounts with other customers or with employees, and each match is investigated.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in customer and employee details and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E58**

Shared details report
Cycle: monthly

**SUCCESS MEASURE · M59**

The review of customer and employee details ran monthly throughout the period, and every exception it raised was investigated and has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C60 **Credit approved independently**

FINANCE LEAD · S67

**REPORTED TODAY**

Most credit limits are approved by someone outside sales. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every credit limit is approved by someone other than the salesperson, within set authority levels.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve credit limits, within what limits, and confirm that no one approves their own.
2. Set the customer master file so that the person who processes a credit limit cannot approve it.
3. Review a recent month of credit limits for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E59**

Credit approval record
Cycle: before each limit is set

**SUCCESS MEASURE · M60**

Every credit limit in the period was approved by someone other than the person who processed it, within the set authority levels.

**IF IT FAILS**

Have any credit limit approved by the person who processed it re-approved independently, and review that person's other credit limits for the period.

## C62 Bureau and fraud database checks

FINANCE LEAD · S67

**REPORTED TODAY**

Bureau and fraud database checks: reported in place only in some areas, cases or periods. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every credit applicant is checked with a credit bureau and a fraud database, such as the Southern African Fraud Prevention Service, before credit is approved.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for credit applicants: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each credit applicant.
3. Look back over credit applicants from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E61**

Credit application file
Cycle: before each approval

**SUCCESS MEASURE · M62**

Every credit applicant in the period has a credit application file showing both checks completed before approval.

**IF IT FAILS**

Where a credit applicant went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C63 Early defaults investigated

FINANCE LEAD · S67

**REPORTED TODAY**

Early defaults investigated: reported in place only in some areas, cases or periods. (answered by Finance)

**TARGET OPERATING PRACTICE**

Accounts that miss their first payments are investigated as possible application fraud before they are treated as bad debt.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in new accounts and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E62**

Early default review
Cycle: monthly

**SUCCESS MEASURE · M63**

The review of new accounts ran monthly throughout the period, and every exception it raised was investigated for application fraud and has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C64 Limit and terms changes approved

FINANCE LEAD · S67

**REPORTED TODAY**

Limit and terms changes approved: reported as set out or agreed but not yet working in practice. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every change to a customer's credit limit or payment terms is approved within set authority and logged.

**IMPLEMENTATION ACTIVITIES**

1. Set who may approve changes to credit limits and payment terms, within what limits, and confirm that no one approves their own.
2. Set the customer master file so that the person who processes a change to a credit limit or payment terms cannot approve it.
3. Review a recent month of changes to credit limits and payment terms for approvals by the same person or after the event, and correct what allowed them.

**RECORDS TO KEEP · E63**

Customer change log
Cycle: before each change takes effect

**SUCCESS MEASURE · M64**

Every change to a credit limit or payment terms in the period was approved by someone other than the person who processed it, within set authority before it took effect.

**IF IT FAILS**

Have any change to a credit limit or payment terms approved by the person who processed it re-approved independently, and review that person's other changes to credit limits and payment terms for the period.

## C65 Statements sent from the system

FINANCE LEAD · S67

**REPORTED TODAY**

Statements sent from the system: reported as not in place. (answered by Finance)

**TARGET OPERATING PRACTICE**

Customer statements are sent directly from the system on a set cycle, so that no employee can intercept or alter them.

**IMPLEMENTATION ACTIVITIES**

1. Set the statement run to send every customer statement directly from the system on a fixed cycle.
2. Remove the ability to suppress or edit a statement without a recorded, approved reason.
3. Check each run's log for suppressed or altered statements.

**RECORDS TO KEEP · E64**

Statement run log
Cycle: monthly

**SUCCESS MEASURE · M65**

At the end of the period, the statement run log shows every statement sent directly from the system, and any exception is approved and recorded.

**IF IT FAILS**

Close the gap, check activity for the period it was open, and treat any unexplained activity as a security incident.

## C74 **Full counts**

FINANCE LEAD · S76

**REPORTED TODAY**

Full counts: reported in place only in some areas, cases or periods. (answered by Finance)

**TARGET OPERATING PRACTICE**

All stock is counted at least once a year, and high-value or fast-moving items more often, under a count plan approved by finance.

**IMPLEMENTATION ACTIVITIES**

1. Set the plan: which stock lines are covered, how often, who carries out the check and who observes it.
2. Prepare check sheets that do not show the recorded position, and compare the results with the record only after the check.
3. Investigate the differences from the first check before any record is adjusted.

**RECORDS TO KEEP · E73**

Count plan and results
Cycle: each year

**SUCCESS MEASURE · M74**

Every check planned for the period was carried out as planned, covering all stock at least once, and every difference was explained before a record was adjusted.

**IF IT FAILS**

Recheck and investigate any unexplained difference, and review access to the items concerned.

## C76 **Differences explained before adjusting**

FINANCE LEAD · S76

**REPORTED TODAY**

Differences explained before adjusting: reported as not in place. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every count difference is investigated and explained, and the adjustment approved by finance, before the stock record is changed.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for stock adjustments: what is checked, by whom, and who may approve an exception.
2. Set the stock system so that no stock adjustment proceeds until the check is recorded as passed.
3. Look back over stock adjustments from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E75**

Adjustment record
Cycle: after each count

**SUCCESS MEASURE · M76**

Every stock adjustment in the period has an adjustment record showing an investigation and an approval before the record was changed.

**IF IT FAILS**

Where a stock adjustment went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C77 **Write-offs approved and supervised**

FINANCE LEAD · S76

**REPORTED TODAY**

Stock is written off by the stores team without approval. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every write-off is approved at a senior level, and the goods are destroyed or disposed of under independent supervision, with a record.

**IMPLEMENTATION ACTIVITIES**

1. Set out the check in the procedure for write-offs: what is checked, by whom, and who may approve an exception.
2. Add the check to the procedure and to the checklist completed for each write-off.
3. Look back over write-offs from the last twelve months, and follow up any that would not have passed the check.

**RECORDS TO KEEP · E76**

Write-off record
Cycle: before each write-off

**SUCCESS MEASURE · M77**

Every write-off in the period has a write-off record showing senior approval and supervised disposal.

**IF IT FAILS**

Where a write-off went ahead without the check, complete the check at once and review anything paid or released before it was found.

## C78 **Shrinkage tracked**

FINANCE LEAD · S76

**REPORTED TODAY**

Shrinkage tracked: reported as set out or agreed but not yet working in practice. (answered by Finance)

**TARGET OPERATING PRACTICE**

Shrinkage and loss rates are tracked each month by site, product and shift, and any rise above the set threshold is investigated.

**IMPLEMENTATION ACTIVITIES**

1. Define the patterns to look for in shrinkage and loss figures and the report, query or alert that finds them.
2. Name who reviews the output monthly and who follows up each exception, independently of the people whose activity is reviewed.
3. Run the review over the last twelve months of data, and follow up what it finds.

**RECORDS TO KEEP · E77**

Shrinkage report
Cycle: monthly

**SUCCESS MEASURE · M78**

The review of shrinkage and loss figures ran monthly throughout the period, and every exception it raised was investigated and has a recorded conclusion.

**IF IT FAILS**

Where an exception proves to be fraud or error, follow the response procedure, correct the control that allowed it and add the pattern to the review.

## C79 How stock is recorded

OPERATIONS LEAD · S76

**REPORTED TODAY**

How stock is recorded: it is not formally recorded. (answered by Operations and sales)

**TARGET OPERATING PRACTICE**

Stock is recorded in an inventory or ERP system, with movements recorded as they happen, so that each count can be compared with an expected quantity.

**IMPLEMENTATION ACTIVITIES**

1. Choose the system or structured record for stock, proportionate to its value.
2. Record opening quantities and every receipt, issue and adjustment as it happens.
3. Compare the record with each count, and investigate the differences.

**RECORDS TO KEEP · E78**

Stock record
Cycle: at each count

**SUCCESS MEASURE · M79**

Every stock line is held on the stock record with its movements, and each count in the period was compared with it.

**IF IT FAILS**

Bring the stock record up to date, and check whether anything was missed while it was out of date.

## C90 Executives and their teams prepared

CHIEF FINANCIAL OFFICER · S87

**REPORTED TODAY**

Most executives with a public profile have agreed a verification method with their assistants and finance teams. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every executive with a public voice or face has been briefed that it can be cloned, and has an agreed verification method that their assistants and finance teams use.

**IMPLEMENTATION ACTIVITIES**

1. List the executives whose voices or faces are public.
2. Brief each of them, and agree a verification method with their assistants and finance teams.
3. Repeat the briefing each year and whenever a new executive is appointed.

**RECORDS TO KEEP · E89**

Executive briefing record
Cycle: each year

**SUCCESS MEASURE · M90**

Every executive with a public profile completed the training within the year, with an agreed verification method in use, and completion is recorded.

**IF IT FAILS**

Follow up incomplete training with the person's manager, and restrict access to sensitive duties where the risk requires it.

## C91 Changes to call-back details verified

CHIEF FINANCIAL OFFICER · S87

**REPORTED TODAY**

Most changes are verified through the old details or another trusted route. (answered by Finance)

**TARGET OPERATING PRACTICE**

Every change to a phone number or email address used for verification is confirmed through the previous details or another trusted route before it is used.

**IMPLEMENTATION ACTIVITIES**

1. Write the confirmation step into the procedure: the previous details or another trusted route, never details supplied with the request.
2. Limit who can make the change, and log how each change was confirmed.
3. Check the changes to call-back details made in the last six months against the log, and confirm any that were not verified.

**RECORDS TO KEEP · E90**

Contact change log
Cycle: whenever a change is requested

**SUCCESS MEASURE · M91**

Every change to call-back details made in the period was confirmed through the previous details or another trusted route before it took effect, or is a recorded and approved exception.

**IF IT FAILS**

Suspend any change to call-back details that was not confirmed until it is verified, and check whether any payment, delivery or access used it.

## C94 Affected people warned

LEGAL AND COMPLIANCE LEAD · S89

**REPORTED TODAY**

Affected people warned: reported as not in place. (answered by IT and information)

**TARGET OPERATING PRACTICE**

When personal data is leaked, the people affected are warned about follow-up fraud, such as phishing that uses their real details, as part of the breach response.

**IMPLEMENTATION ACTIVITIES**

1. Write the procedure, naming who decides and who acts at each step.
2. Brief the people with a role in it, and keep the contact details it relies on current.
3. Test it each year with an exercise or a real case, and record what changed as a result.

**RECORDS TO KEEP · E93**

Breach response record
Cycle: each year

**SUCCESS MEASURE · M94**

In the period, everyone affected by a leak was warned about follow-up fraud.

**IF IT FAILS**

Where the procedure was not followed or did not work, record why, correct it and brief the people concerned.

APPENDIX D

# Records management should maintain

The records each control should produce as it operates, for management to keep. MK has not requested, received or examined any of them. Independent review of evidence is a separate Advisory service; this report does not perform it.

| REF | RECORD AND WHAT IT SHOWS | CONTROLS | KEPT BY |
|---|---|---|---|
| E01 | Training completion record: each new employee, the training completed and the date. | C01 | HR and payroll lead |
| E02 | Donation approval file: the recipient, the checks made, any link found and who approved the payment. | C02 | Ethics lead |
| E03 | Supplier set-up file: the result and source of each check, who captured the supplier and who approved it. | C03 | Procurement lead |
| E04 | Supplier set-up file: the CIPC or other independent search result, the directors and owners identified and the date. | C04 | Procurement lead |
| E05 | Supplier and employee match report: the comparison run, each match found and its conclusion. | C05 | Procurement lead |
| E06 | Supplier re-check log: each supplier re-checked, the checks repeated, the result and any action taken. | C06 | Procurement lead |
| E07 | Dormant supplier report: suppliers unused for the set period, the date each was deactivated and any reactivation with its checks. | C07 | Procurement lead |
| E08 | Bank detail change log: each request, how and by whom it was confirmed, the number used and the date the change took effect. | C08 | Finance lead |
| E09 | Verification rule record: the rule, briefing records and the results of each test. | C09 | Finance lead |
| E10 | Account verification result: the service used, the result and the date. | C10 | Procurement lead |
| E11 | Access and delegation list: who can place orders, who can approve payments, approved exceptions and the date of the last review. | C11 | Procurement lead |
| E12 | Purchase order or approval record: what was approved, by whom, the amount and the date. | C12 | Procurement lead |
| E13 | Goods received note: what was received, the quantity, who received it and the date. | C13 | Operations lead |
| E14 | Goods received note: the quantities ordered, delivered and received, any difference and who checked them. | C14 | Operations lead |
| E15 | Service delivery confirmation: the service, the person who received it, what they confirmed and the date. | C15 | Operations lead |
| E16 | Payment file: the invoice matched to the approval and to the confirmation of receipt, and how any difference was resolved. | C16 | Finance lead |
| E17 | Provider access register: each provider, the access granted, its justification and the date of the last review. | C17 | Procurement lead |
| E18 | Banking platform approval settings report: the approval rules for each payment type, the users who can approve and the date checked. | C18 | Finance lead |
| E19 | Procurement file: the quotes or tender obtained, or the approved reason for not obtaining them. | C19 | Procurement lead |
| E20 | Evaluation file: the criteria and the date they were set, each evaluator's scores and conflict declaration, and the decision. | C20 | Procurement lead |
| E21 | Declarations register: each person, their declaration, the date and any action taken. | C21 | Legal and compliance lead |
| E22 | Card statement reconciliation: the statement, the supporting receipts, the reviewer and the follow-up of each unsupported transaction. | C22 | Finance lead |
| E23 | Intermediary due diligence file: the ownership, reputation and public official checks, their results and the approval. | C23 | Procurement lead |
| E24 | Monthly exception review: the patterns checked, the exceptions found, who reviewed them and the conclusion for each. | C24 | Internal audit |
| E25 | Review report: the scope, the findings, management's responses and the status of each finding. | C25, C35 | Internal audit; HR and payroll lead |
| E26 | Split order report: orders grouped by supplier and period, each instance found and its conclusion. | C26 | Procurement lead |
| E27 | Monthly payment review: the list reviewed, the reviewer, each query raised and its answer. | C27 | Finance lead |
| E28 | Contract register: each contract's supplier, value, term, owner and renewal or end date. | C28 | Procurement lead |

| REF | RECORD AND WHAT IT SHOWS | CONTROLS | KEPT BY |
|---|---|---|---|
| E29 | Variation approval record: each variation, its value, who requested it, who approved it and when. | C29 | Procurement lead |
| E30 | Variation approval record: each variation above the threshold, its percentage of the original value and the senior approval. | C30 | Procurement lead |
| E31 | Contract register: each ongoing or significant supplier, whether a signed contract exists and where it is kept. | C31 | Procurement lead |
| E32 | Bank detail change log: each request, how and by whom it was confirmed and the date the change took effect. | C32 | HR and payroll lead |
| E33 | Payroll review checklist: the run, the variances explained, the reviewer and the date. | C33 | HR and payroll lead |
| E34 | Headcount verification report: the population covered, who carried it out, each person not matched and the outcome. | C34 | HR and payroll lead |
| E35 | Leaver reconciliation: the HR leaver list compared with the payroll, who prepared it and any leaver still being paid. | C36 | HR and payroll lead |
| E36 | Identity verification result: the service used, the result and the date. | C37 | HR and payroll lead |
| E37 | Qualification verification result: the qualification, the response from the institution or SAQA and the date. | C38 | HR and payroll lead |
| E38 | Remote appointment identity record: how identity was confirmed, the result, and any failed check with its review. | C39 | HR and payroll lead |
| E39 | Payment file control record: the protection used, the check performed each pay run and any exception. | C40 | HR and payroll lead |
| E40 | Cash pay-out record: each pay-out, the two people present and their signatures. | C41 | Finance lead |
| E41 | Timesheet approval record: each timesheet, the hours claimed, the supervisor's approval and the date. | C42 | HR and payroll lead |
| E42 | Claim approval record: each claim, its receipts, who approved it and when. | C43 | Finance lead |
| E43 | Broker invoice reconciliation: the invoice, the attendance records compared, each difference and its resolution. | C44 | Operations lead |
| E44 | List of high-risk roles: each role, why it is high-risk, the people in it and the date last reviewed. | C45 | HR and payroll lead |
| E45 | Cover arrangement log: each cover arrangement, the duties covered, the conflict check and the approval. | C46 | HR and payroll lead |
| E46 | Cover and skills matrix: each critical process, the people trained to perform it and the date checked. | C47 | HR and payroll lead |
| E47 | Block leave record: each person in a sensitive role, the dates of their block leave, who did their work and any approved exception. | C48 | HR and payroll lead |
| E48 | Concerns log: each concern, who assessed it, the outcome and when. | C49 | HR and payroll lead |
| E49 | Support programme record: the support offered, how it was communicated and its use in aggregate. | C50 | HR and payroll lead |
| E50 | Refund approval record: each refund or credit note, who processed it, who approved it and when. | C51 | Commercial and customer lead |
| E51 | Returns record: the goods returned, who received them back into stock and the credit issued. | C52 | Commercial and customer lead |
| E52 | Refund pattern review: the patterns checked, each exception found and its conclusion. | C53 | Commercial and customer lead |
| E53 | Post-period reversal review: the reversals reviewed, those linked to period-end sales and the conclusion for each. | C54 | Commercial and customer lead |
| E54 | Refund evidence check: the images or documents checked, the method used and the result. | C55 | Commercial and customer lead |
| E55 | Customer onboarding file: the checks completed, by whom and the date. | C56 | Commercial and customer lead |
| E56 | Customer onboarding file: the registration search, the authorised representatives confirmed and the date. | C57 | Commercial and customer lead |
| E57 | Customer change log: each change, how it was verified, who made it and when. | C58 | Commercial and customer lead |
| E58 | Shared details report: each match found, who investigated it and the conclusion. | C59 | Commercial and customer lead |
| E59 | Credit approval record: each limit, who requested it, who approved it, the authority level and the date. | C60 | Finance lead |

| REF | RECORD AND WHAT IT SHOWS | CONTROLS | KEPT BY |
|---|---|---|---|
| E60 | Credit application file: the information verified, the source used, the result and the date. | C61 | Finance lead |
| E61 | Credit application file: the bureau and fraud database results and the date. | C62 | Finance lead |
| E62 | Early default review: each account that missed its first payments, the checks made and the conclusion. | C63 | Finance lead |
| E63 | Customer change log: each change, who requested and approved it, and the date. | C64 | Finance lead |
| E64 | Statement run log: each run, the customers sent statements, and any statement suppressed or altered with the reason. | C65 | Finance lead |
| E65 | Claims screening log: each claim screened, the indicators triggered and the referral outcome. | C66 | Commercial and customer lead |
| E66 | Delivery-to-invoice match report: deliveries and services provided, the invoices matched, and each unbilled item with its outcome. | C67 | Finance lead |
| E67 | Template register: each template, the bank account and warning it carries and the date checked. | C68 | Finance lead |
| E68 | Price approval record: each price or discount outside the standard, who requested and approved it, and the date. | C69 | Commercial and customer lead |
| E69 | Commission verification: the sales claimed, the customer activity checked and the commission approved. | C70 | Commercial and customer lead |
| E70 | Voucher issue and redemption report: each voucher or code, who issued it, when it was redeemed and any duplicate blocked. | C71 | Commercial and customer lead |
| E71 | Flag review log: each flagged decision, the reviewer, the evidence considered and the outcome. | C72 | Fraud risk lead |
| E72 | Daily cash reconciliation: takings at each cash point compared with sales records, the preparer and reviewer, and each shortage or surplus with its explanation. | C73 | Operations lead |
| E73 | Count plan and results: the plan, the lines counted, the dates and the differences found. | C74 | Finance lead |
| E74 | Count sheets: the count instructions, sheets without recorded quantities and the names of counters and observers. | C75 | Finance lead |
| E75 | Adjustment record: each difference, its investigation, the explanation and the approval. | C76 | Finance lead |
| E76 | Write-off record: each write-off, its senior approval, and the disposal or destruction certificate with the supervisor's name. | C77 | Finance lead |
| E77 | Shrinkage report: losses by site, product and shift, each rise above the threshold and its investigation. | C78 | Finance lead |
| E78 | Stock record: each stock line, its movements and the quantity expected at any time. | C79 | Operations lead |
| E79 | Device disposal record: each device, the wipe method, who performed it, the date and where the device went. | C80 | IT lead |
| E80 | Release record: the payment confirmed on the bank statement, who confirmed it and the date of release. | C81 | Finance lead |
| E81 | Release log: each changed instruction, how it was verified, the collector's identity check and the release. | C82 | Operations lead |
| E82 | Fuel exception report: each vehicle's fuel, distance and expected consumption, and each exception with its outcome. | C83 | Operations lead |
| E83 | Dispatch record: the approved order, the goods dispatched and who released them. | C84 | Operations lead |
| E84 | Organised theft assessment: the sites and assets assessed, the threats identified and the measures agreed with the security provider. | C85 | Operations lead |
| E85 | Loss report: losses by type and location over time, and the actions taken. | C86 | Finance lead |
| E86 | Email security report: the multi-factor status of every account, including shared mailboxes. | C87 | IT lead |
| E87 | Verification rule record: the rule, briefing records, call-back records and the results of each test. | C88 | Chief financial officer |
| E88 | Verification method record: the agreed method, briefing records and the results of each test. | C89 | Chief financial officer |
| E89 | Executive briefing record: each executive briefed, the verification method agreed and the people told to use it. | C90 | Chief financial officer |
| E90 | Contact change log: each change to supplier or executive contact details, how it was confirmed and when. | C91 | Chief financial officer |
| E91 | Customer authentication report: the settings on each login route, lockouts and account takeover cases. | C92 | IT lead |

| REF | RECORD AND WHAT IT SHOWS | CONTROLS | KEPT BY |
|---|---|---|---|
| E92 | Breach response procedure: the procedure, the notification templates, and each compromise with its notification dates and any justified delay. | C93 | IT lead |
| E93 | Breach response record: each leak, the people warned, the warning sent and the date. | C94 | Legal and compliance lead |
| E94 | Reset log: each reset, how the requester was verified, by whom and when. | C95 | IT lead |
| E95 | Multi-factor coverage report: each system and access route in scope, its multi-factor setting and any approved exception. | C96 | IT lead |
| E96 | Access review: each system, who has access and why, the export restrictions and the review date. | C97 | Legal and compliance lead |
| E97 | Approval numbers register: each number used for approvals, its SIM-swap lock or replacement and the date confirmed. | C98 | IT lead |
| E98 | AI assistant permissions register: each assistant, the permissions granted, the approvals required and the date reviewed. | C99 | IT lead |
| E99 | Guidance record: the guidance issued, to whom and when. | C100 | Commercial and customer lead |
| E100 | Compromise response plan: the plan, its contact list and the record of each test or incident. | C101 | IT lead |
| E101 | Impersonation log: each impersonation found, the takedown request and the date it was removed. | C102 | Chief financial officer |
| E102 | Domain protection report: each domain, its SPF, DKIM and DMARC settings and the date checked. | C103 | IT lead |

APPENDIX E

# Action register

Every action in the programme, grouped by proposed stage. The windows are proposals for planning, not deadlines or estimates.

| REF | ACTION | OWNER | DELIVERABLE | COMPLETE WHEN |
|---|---|---|---|---|
| **STAGE 1 · ESTABLISH THE FACTS** Proposed start: month 1 | | | | |
| A01 | Obtain the 2 outstanding answers held by Risk and investigations: process owners take part and updated when the business changes. | Fraud risk lead | An answer to each question, or each recorded as an open item with a named owner. | No question is left declined or unanswered without a recorded owner. |
| A02 | Obtain the 1 outstanding answer held by HR and payroll: payroll data analysed. | HR and payroll lead | An answer to each question, or each recorded as an open item with a named owner. | No question is left declined or unanswered without a recorded owner. |
| A03 | Obtain the 1 outstanding answer held by Finance: payments matched to invoices. | Finance lead | An answer to each question, or each recorded as an open item with a named owner. | No question is left declined or unanswered without a recorded owner. |
| A04 | Obtain the 2 outstanding answers held by Operations and sales: refunds to the original source and register verified physically. | Commercial and customer lead | An answer to each question, or each recorded as an open item with a named owner. | No question is left declined or unanswered without a recorded owner. |
| A05 | Obtain the 1 outstanding answer held by Legal, compliance and ethics: retaliation risk assessed. | Ethics lead | An answer to each question, or each recorded as an open item with a named owner. | No question is left declined or unanswered without a recorded owner. |
| **STAGE 2 · DECIDE AND ASSIGN** Proposed start: months 1 to 3 | | | | |
| A06 | Name the executive accountable for ethics, where 1 scenario is open or unresolved. | Chief executive | A named accountable executive for the area. | The area has one named executive who has accepted the role. |
| A07 | Name the executive accountable for procurement, where 13 scenarios are open or unresolved. | Chief executive | A named accountable executive for the area. | The area has one named executive who has accepted the role. |
| A08 | Name the executive accountable for people, where 11 scenarios are open or unresolved. | Chief executive | A named accountable executive for the area. | The area has one named executive who has accepted the role. |
| A09 | Name the executive accountable for customers, where 10 scenarios are open or unresolved. | Chief executive | A named accountable executive for the area. | The area has one named executive who has accepted the role. |
| A10 | Name the executive accountable for assets, where 9 scenarios are open or unresolved. | Chief executive | A named accountable executive for the area. | The area has one named executive who has accepted the role. |
| A11 | Name the executive accountable for digital channels, where 14 scenarios are open or unresolved. | Chief executive | A named accountable executive for the area. | The area has one named executive who has accepted the role. |
| A12 | Decide which of the 58 scenarios with a control reported as a gap to address in this cycle, and in what order, using the decision factors in the finding register. | Chief executive | A recorded selection and order, with the factors that decided each choice. | Every open scenario is either selected, deferred with a reason, or accepted as a risk at the right level. |
| A13 | Approve the target design for each selected control, using the target practice, records and measure in the control blueprint register. | Chief executive | Approved designs, each with an owner and the records it will keep. | Each selected control has an approved design and an owner. |
| **STAGE 3 · PUT THE SELECTED CONTROLS IN PLACE** Proposed start: once designs are approved | | | | |
| A14 | Put in place the control the ethics lead owns: recipients checked for links (C02). | Ethics lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A15 | Put in place the 7 controls the procurement lead owns: new supplier process (C03), bank account verified (C10), orderer is not payment approver (C11), provider access limited (C17), evaluation against set criteria (C20) and intermediaries vetted (C23) and 1 more. | Procurement lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |

| REF | ACTION | OWNER | DELIVERABLE | COMPLETE WHEN |
|---|---|---|---|---|
| A16 | Put in place the 14 controls the finance lead owns: change confirmed with supplier (C08), familiar caller still verified (C09), three-way match (C16), two approvers on banking platform (C18), independent reconciliation (C22) and senior review of supplier payments (C27) and 8 more. | Finance lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A17 | Put in place the 2 controls the legal and compliance lead owns: annual interest declarations (C21) and access to personal information limited (C97). | Legal and compliance lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A18 | Put in place the 8 controls the HR and payroll lead owns: bank changes confirmed with employee (C32), payroll reviewed by another person (C33), leavers removed before next run (C36), identity verified (C37), remote appointee identity confirmed (C39) and payment file protected (C40) and 2 more. | HR and payroll lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A19 | Put in place the 6 controls the operations lead owns: broker invoices against attendance (C44), daily reconciliation (C73), changed collection instructions verified (C82), fuel matched to distance (C83), dispatch matched to orders (C84) and organised theft assessed (C85). | Operations lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A20 | Put in place the 7 controls the commercial and customer lead owns: refunds approved independently (C51), customer detail changes verified (C58), fraud indicators screened (C66), non-standard prices approved (C69), agent sales verified (C70) and vouchers controlled in the system (C71) and 1 more. | Commercial and customer lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A21 | Put in place the control the fraud risk lead owns: human review before a customer is blocked (C72). | Fraud risk lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A22 | Put in place the 10 controls the IT lead owns: devices wiped before disposal (C80), multi-factor on all email (C87), customer logins protected (C92), compromises reported as POPIA requires (C93), help desk resets verified (C95) and multi-factor on critical systems (C96) and 4 more. | IT lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A23 | Put in place the 3 controls the chief financial officer owns: email never enough on its own (C88), verification for calls, voice notes and video (C89) and brand impersonation monitored and removed (C102). | Chief financial officer | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| **STAGE 4 · STRENGTHEN FURTHER DEFENCES** Proposed start: after the first controls are in place | | | | |
| A24 | Strengthen the 9 controls the HR and payroll lead owns: training on joining (C01), headcount verification done (C34), independent review of payroll (C35), qualifications verified (C38), high-risk roles identified (C45) and no conflicting duties when covering (C46) and 3 more. | HR and payroll lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A25 | Strengthen the 10 controls the procurement lead owns: directors identified (C04), directors compared with staff (C05), suppliers re-checked (C06), dormant suppliers deactivated (C07), approved order before commitment (C12) and quote and tender thresholds (C19) and 4 more. | Procurement lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A26 | Strengthen the 4 controls the operations lead owns: receipt recorded before payment (C13), quantities checked (C14), services confirmed (C15) and how stock is recorded (C79). | Operations lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A27 | Strengthen the 2 controls the internal audit owns: data reviewed for unusual patterns (C24) and independent review of procurement (C25). | Internal audit | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A28 | Strengthen the 7 controls the commercial and customer lead owns: returns received before credit (C52), refund patterns reviewed (C53), post-period reversals reviewed (C54), claim evidence checked for AI (C55), defined onboarding (C56) and business customers verified (C57) and 1 more. | Commercial and customer lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |

| REF | ACTION | OWNER | DELIVERABLE | COMPLETE WHEN |
|---|---|---|---|---|
| A29 | Strengthen the 9 controls the finance lead owns: credit approved independently (C60), bureau and fraud database checks (C62), early defaults investigated (C63), limit and terms changes approved (C64), statements sent from the system (C65) and full counts (C74) and 3 more. | Finance lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A30 | Strengthen the 2 controls the chief financial officer owns: executives and their teams prepared (C90) and changes to call-back details verified (C91). | Chief financial officer | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| A31 | Strengthen the control the legal and compliance lead owns: affected people warned (C94). | Legal and compliance lead | Each control operating to its approved design, with the records named in its blueprint kept from the first case. | Each control has started operating, and its records exist for every case since it started. |
| **STAGE 5 · OPERATE, MEASURE AND REPORT** From the first control in operation, through month 12 | | | | |
| A32 | Check each of the 17 controls owned by the HR and payroll lead against its success measure once it has completed its first full operating cycle. | HR and payroll lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A33 | Check the control owned by the ethics lead against its success measure once it has completed its first full operating cycle. | Ethics lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A34 | Check each of the 17 controls owned by the procurement lead against its success measure once it has completed its first full operating cycle. | Procurement lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A35 | Check each of the 23 controls owned by the finance lead against its success measure once it has completed its first full operating cycle. | Finance lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A36 | Check each of the 10 controls owned by the operations lead against its success measure once it has completed its first full operating cycle. | Operations lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A37 | Check each of the 3 controls owned by the legal and compliance lead against its success measure once it has completed its first full operating cycle. | Legal and compliance lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A38 | Check each of the 2 controls owned by the internal audit against its success measure once it has completed its first full operating cycle. | Internal audit | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A39 | Check each of the 14 controls owned by the commercial and customer lead against its success measure once it has completed its first full operating cycle. | Commercial and customer lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A40 | Check the control owned by the fraud risk lead against its success measure once it has completed its first full operating cycle. | Fraud risk lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A41 | Check each of the 10 controls owned by the IT lead against its success measure once it has completed its first full operating cycle. | IT lead | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A42 | Check each of the 5 controls owned by the chief financial officer against its success measure once it has completed its first full operating cycle. | Chief financial officer | A first-cycle review for each control, with exceptions and their resolution. | Each control has met its success measure for one full cycle, or has a recorded correction. |
| A43 | Report the status of every open and unresolved scenario to the board at each of its meetings until each is closed, deferred with a reason or accepted. | Chief executive | A one-page status: scenario, owner, controls in place, controls outstanding, next step. | The status is received and minuted at each meeting. |

APPENDIX F

# Management scorecard

The success measures, grouped by the owner who reports them, with each control's operating cycle. Each measure is stated once, in full, in its control's blueprint (Appendix C) and in the supporting workbook.

| MEASURE | CONTROL | CONTROL NAME | OPERATING CYCLE |
|---|---|---|---|
| **CHIEF FINANCIAL OFFICER** 5 measures | | | |
| M88 | C88 | Email never enough on its own | each year |
| M89 | C89 | Verification for calls, voice notes and video | each year |
| M90 | C90 | Executives and their teams prepared | each year |
| M91 | C91 | Changes to call-back details verified | whenever a change is requested |
| M102 | C102 | Brand impersonation monitored and removed | weekly |
| **COMMERCIAL AND CUSTOMER LEAD** 14 measures | | | |
| M51 | C51 | Refunds approved independently | before each refund is paid |
| M52 | C52 | Returns received before credit | before each credit is issued |
| M53 | C53 | Refund patterns reviewed | monthly |
| M54 | C54 | Post-period reversals reviewed | after each period end |
| M55 | C55 | Claim evidence checked for AI | before each approval |
| M56 | C56 | Defined onboarding | before each account is opened |
| M57 | C57 | Business customers verified | before each account is opened |
| M58 | C58 | Customer detail changes verified | whenever a change is requested |
| M59 | C59 | Shared details flagged | monthly |
| M66 | C66 | Fraud indicators screened | for every claim |
| M69 | C69 | Non-standard prices approved | before each sale is invoiced |
| M70 | C70 | Agent sales verified | before each commission payment |
| M71 | C71 | Vouchers controlled in the system | monthly |
| M100 | C100 | Staff guided on what not to share | each year |
| **ETHICS LEAD** 1 measure | | | |
| M02 | C02 | Recipients checked for links | before each commitment |
| **FINANCE LEAD** 23 measures | | | |
| M08 | C08 | Change confirmed with supplier | whenever a change is requested |
| M09 | C09 | Familiar caller still verified | each year |
| M16 | C16 | Three-way match | before each payment |
| M18 | C18 | Two approvers on banking platform | each quarter |
| M22 | C22 | Independent reconciliation | monthly |
| M27 | C27 | Senior review of supplier payments | monthly |
| M41 | C41 | Two people pay out cash | each pay run |
| M43 | C43 | Claims approved by a manager | before each payment |
| M60 | C60 | Credit approved independently | before each limit is set |
| M61 | C61 | Application documents verified | before each approval |
| M62 | C62 | Bureau and fraud database checks | before each approval |

| MEASURE | CONTROL | CONTROL NAME | OPERATING CYCLE |
|---|---|---|---|
| M63 | C63 | Early defaults investigated | monthly |
| M64 | C64 | Limit and terms changes approved | before each change takes effect |
| M65 | C65 | Statements sent from the system | monthly |
| M67 | C67 | Everything supplied is billed | weekly |
| M68 | C68 | Customers warned about payment redirection | each quarter |
| M74 | C74 | Full counts | each year |
| M75 | C75 | Independent blind counts | at each count |
| M76 | C76 | Differences explained before adjusting | after each count |
| M77 | C77 | Write-offs approved and supervised | before each write-off |
| M78 | C78 | Shrinkage tracked | monthly |
| M81 | C81 | Paid before collection | before each release |
| M86 | C86 | Losses tracked and reported | monthly |
| **FRAUD RISK LEAD** 1 measure | | | |
| M72 | C72 | Human review before a customer is blocked | each year |
| **HR AND PAYROLL LEAD** 17 measures | | | |
| M01 | C01 | Training on joining | monthly |
| M32 | C32 | Bank changes confirmed with employee | whenever a change is requested |
| M33 | C33 | Payroll reviewed by another person | each pay run |
| M34 | C34 | Headcount verification done | every two years |
| M35 | C35 | Independent review of payroll | within the last two years |
| M36 | C36 | Leavers removed before next run | each pay run |
| M37 | C37 | Identity verified | before each start date |
| M38 | C38 | Qualifications verified | before each offer is final |
| M39 | C39 | Remote appointee identity confirmed | before access and pay are set up |
| M40 | C40 | Payment file protected | each pay run |
| M42 | C42 | Hours approved by supervisor | each pay run |
| M45 | C45 | High-risk roles identified | each year |
| M46 | C46 | No conflicting duties when covering | whenever cover is arranged |
| M47 | C47 | No single point of knowledge | each year |
| M48 | C48 | Block leave required | each year |
| M49 | C49 | Concerns raised fairly | each year |
| M50 | C50 | Support for financial pressure | each year |
| **INTERNAL AUDIT** 2 measures | | | |
| M24 | C24 | Data reviewed for unusual patterns | monthly |
| M25 | C25 | Independent review of procurement | within the last two years |
| **IT LEAD** 10 measures | | | |
| M80 | C80 | Devices wiped before disposal | before each device leaves use |
| M87 | C87 | Multi-factor on all email | monthly |
| M92 | C92 | Customer logins protected | monthly |
| M93 | C93 | Compromises reported as POPIA requires | each year |
| M95 | C95 | Help desk resets verified | whenever a reset is requested |

| MEASURE | CONTROL | CONTROL NAME | OPERATING CYCLE |
|---|---|---|---|
| M96 | C96 | Multi-factor on critical systems | monthly |
| M98 | C98 | Approval numbers protected | each quarter |
| M99 | C99 | Assistant permissions limited | each quarter |
| M101 | C101 | Compromise playbook | each year |
| M103 | C103 | Domain protected against spoofing | each quarter |
| **LEGAL AND COMPLIANCE LEAD** 3 measures | | | |
| M21 | C21 | Annual interest declarations | each year and when circumstances change |
| M94 | C94 | Affected people warned | each year |
| M97 | C97 | Access to personal information limited | each quarter |
| **OPERATIONS LEAD** 10 measures | | | |
| M13 | C13 | Receipt recorded before payment | before each payment |
| M14 | C14 | Quantities checked | at each delivery |
| M15 | C15 | Services confirmed | before each payment |
| M44 | C44 | Broker invoices against attendance | before each payment |
| M73 | C73 | Daily reconciliation | daily |
| M79 | C79 | How stock is recorded | at each count |
| M82 | C82 | Changed collection instructions verified | whenever an instruction changes |
| M83 | C83 | Fuel matched to distance | monthly |
| M84 | C84 | Dispatch matched to orders | before each dispatch |
| M85 | C85 | Organised theft assessed | each year |
| **PROCUREMENT LEAD** 17 measures | | | |
| M03 | C03 | New supplier process | before each new supplier is first paid |
| M04 | C04 | Directors identified | before each new supplier is first paid |
| M05 | C05 | Directors compared with staff | at set-up and at least once a year |
| M06 | C06 | Suppliers re-checked | each year |
| M07 | C07 | Dormant suppliers deactivated | each quarter |
| M10 | C10 | Bank account verified | before each new supplier is first paid |
| M11 | C11 | Orderer is not payment approver | each year |
| M12 | C12 | Approved order before commitment | before each commitment |
| M17 | C17 | Provider access limited | each year |
| M19 | C19 | Quote and tender thresholds | before each commitment |
| M20 | C20 | Evaluation against set criteria | for each competitive purchase |
| M23 | C23 | Intermediaries vetted | before each appointment |
| M26 | C26 | Split orders monitored | monthly |
| M28 | C28 | Contract register | each quarter |
| M29 | C29 | Variations approved first | before each variation proceeds |
| M30 | C30 | Large variations escalated | before each large variation proceeds |
| M31 | C31 | Written supplier contracts | each quarter |

APPENDIX G

# Answer relationships

For each control reported fully in place, every related practice of the same scenario reported weaker, with no case yet or outstanding, and how the two relate. A practice answered "not applicable" is outside scope and is not listed. Only answers that cannot both be right, or a control lacking an input it needs, are unresolved inconsistencies; a reviewed pair the answers leave open is a question to clarify; a pair not yet reviewed supports no conclusion.

| SCENARIO | CONTROL REPORTED IN PLACE | RELATED PRACTICE AND ITS ANSWER | RELATIONSHIP | WHAT IT MEANS |
|---|---|---|---|---|
| S13 | **Fraud risks assessed** | Process owners take part: outstanding. | **INFORMATION OUTSTANDING**<br>From the answer | Process owners take part is still to be answered, so nothing is concluded about how it bears on fraud risks assessed. |
| S25 | **Code accessible to staff** | Training on joining: reported in place only in some areas, cases or periods. | **FURTHER DEFENCE WEAKER; CONTROL STANDS**<br>Reviewed pair | Fraud and ethics training at joining is distinct from explaining conduct standards where employees work; induction is only one of the places Code accessible to staff names. |
| S100 | **Identities kept confidential** | Retaliation risk assessed: outstanding. | **INFORMATION OUTSTANDING**<br>From the answer | Retaliation risk assessed is still to be answered, so nothing is concluded about how it bears on identities kept confidential. |
| S100 | **Retaliation prohibited and punished** | Retaliation risk assessed: outstanding. | **INFORMATION OUTSTANDING**<br>From the answer | Retaliation risk assessed is still to be answered, so nothing is concluded about how it bears on retaliation prohibited and punished. |

APPENDIX H

# Outstanding information

Every question asked and not answered. A declined question, a question answered "I don't know" and a question still waiting are all outstanding; none is treated as answered.

| REF | CONTROL | STATUS | FUNCTION | SCENARIO |
|---|---|---|---|---|
| O01 | **Process owners take part** | Not known by the function asked | Risk and investigations | Fraud risks are never identified |
| O02 | **Updated when the business changes** | Not known by the function asked | Risk and investigations | The assessment goes stale as the business changes |
| O03 | **Payroll data analysed** | Not known by the function asked | HR and payroll | Ghost employees are paid |
| O04 | **Payments matched to invoices** | Not known by the function asked | Finance | Credit is obtained with fabricated documents |
| O05 | **Refunds to the original source** | Not known by the function asked | Operations and sales | Refunds are stolen |
| O06 | **Register verified physically** | Not known by the function asked | Operations and sales | Portable and fixed assets go missing |
| O07 | **Retaliation risk assessed** | Not known by the function asked | Legal, compliance and ethics | A reporter is exposed or retaliated against |

APPENDIX I

# Roles used in this report

Each consolidated role and the method's own suggested owners behind it.

| ROLE IN THIS REPORT | METHOD WORDING |
|---|---|
| **Chief financial officer** | CFO and head of IT together |
| **Commercial and customer lead** | Channel or sales manager; Claims manager; Communications or marketing manager; Customer onboarding or operations manager; Customer service or finance manager; Marketing manager; Sales or commercial manager |
| **Ethics lead** | CSI or sustainability lead |
| **Finance lead** | Billing or debtors manager; Credit manager; Creditors manager; Creditors manager or financial controller; Financial controller; Financial controller or internal audit; Financial controller, with the asset owner |
| **Fraud risk lead** | Fraud or risk lead |
| **HR and payroll lead** | HR manager; HR manager, with the head of IT; HR or learning lead; HR or payroll manager; HR or recruitment manager; Payroll manager; Payroll manager or financial controller; Payroll manager or internal audit |
| **Internal audit** | Internal audit or financial controller |
| **IT lead** | Head of IT or IT provider; Head of IT or information security; Head of IT or the person responsible for AI tools; Head of IT, with finance; Head of digital channels |
| **Legal and compliance lead** | Compliance lead or HR; Information officer (POPIA) |
| **Operations lead** | Asset or facilities manager; Fleet manager; Logistics manager; Operations manager; Operations or financial manager; Security manager; Store, branch or cash office manager; Stores or operations manager; Warehouse or stores manager |
| **Procurement lead** | Contract manager; Head of procurement or CFO; Head of procurement or bid committee secretary; Head of procurement, with the business owner of each relationship; Procurement manager; Procurement or creditors manager; Procurement or the finance manager |

APPENDIX J

# Information coverage

What the assessment establishes and what remains unknown: the confirmations answered in each area and the diagnostic questions put to each function. Questions the method did not ask are not counted, and nothing is concluded about them.

| AREA | CONFIRMATIONS THAT APPLY | ANSWERED | SHARE ANSWERED |
|---|---|---|---|
| **Fraud governance and accountability** | 12 | 12 | 100% |
| **Fraud risk assessment** | 6 | 5 | 83% |
| **Ethics, integrity and anti-corruption** | 10 | 10 | 100% |
| **Third parties and supply chain** | 14 | 14 | 100% |
| **People, payroll and insider risk** | 11 | 11 | 100% |
| **Finance, banking and financial reporting** | 12 | 12 | 100% |
| **Customers, revenue and products** | 10 | 10 | 100% |
| **Assets, cash and inventory** | 10 | 9 | 90% |
| **Digital, cyber-enabled and identity fraud** | 14 | 14 | 100% |
| **Detection, speak-up and response** | 9 | 9 | 100% |

## Diagnostic questions put to functions

| FUNCTION | ASKED | ANSWERED | DECLINED | NOT KNOWN | WAITING |
|---|---|---|---|---|---|
| **Executive and governance** | 2 | 2 | 0 | 0 | 0 |
| **Procurement** | 25 | 25 | 0 | 0 | 0 |
| **Finance** | 21 | 20 | 0 | 1 | 0 |
| **HR and payroll** | 18 | 17 | 0 | 1 | 0 |
| **Operations and sales** | 20 | 18 | 0 | 2 | 0 |
| **IT and information** | 17 | 17 | 0 | 0 | 0 |
| **Risk and investigations** | 22 | 20 | 0 | 2 | 0 |
| **Legal, compliance and ethics** | 5 | 4 | 0 | 1 | 0 |